80 TO 0 IN UNDER 5 SECONDS: FALSIFYING A MEDICAL PATIENT'S VITALS

Douglas McKee

WHO AM I?

- Douglas McKee
- Senior Security Researcher for McAfee's Advanced Threat Research team
- 8+ years experience in vulnerability research, penetration testing and forensics
- @fulmetalpackets
- Not a medical doctor

McAfee™
Together is power.

OUTLINE

- Why these medical devices?
- Overview of systems
- RWHAT?
- Reversing the protocol
- Replay attacks
- Demo
- Impact Scenarios
- Mitigations

WHY?

- POTENTIAL IMPACT OF MEDICAL DEVICES
- PATIENT MONITORING WILL ALWAYS BE A NECESSARY
  - "VITAL SIGNS ARE INTEGRAL TO CLINICAL DECISION MAKING" – DR. S. NORDECK
- RELIANCE ON TECHNOLOGY IN MEDICAL FIELD
  - "WE HAVE AN IMPLICIT TRUST IN THESE TYPES OF TECHNOLOGIES," TULLY SAYS. "WE DON'T EVER GET ANY CYBERSECURITY TRAINING IN MEDICAL SCHOOL. IT'S NOT SOMETHING THAT EVER COMES UP IN OUR LITERATURE." DR. JEFF TULLY*

*https://www.hpe.com/us/en/insights/articles/medical-device-security-hacking-prevention-measures-1806.html

Patient Monitor (PM)

- Bedside monitor
- Monitors patient's vitals – Heartrate, Blood pressure, O2 levels, etc
- Has wired and wireless (optional) networkin
- Contains Personal Identifiable Information (PII)
- *General pictures, not tested model

Central Monitoring Station (CMS)

- Runs Embedded Windows on CF Card
  - Windows XP or Windows 7
- Has two Ethernet ports for two networks
- Runs main application in limited user mode
- A central station that receives data from Patient Monitors
- Thanks Ebay!

POTENTIAL ATTACK VECTORS

- OS
- Application

POTENTIAL ATTACK VECTORS

- OS
- Application
- Firmware/hardware
- **Network**
  - **Modify patient information?**

RWHAT?

RWHAT packets

All monitoring devices on the [redacted] Network periodically broadcast information about themselves in "RWHAT" packets. Among other things, RWHAT packets contain IP address, port number, name, and offered services information about each device.

All monitoring devices listen for RWHAT packets, and maintain a database of information about other devices on the network. When devices need to communicate, the appropriate IP address information is obtained from the database, [redacted] Network-protocol messages are created, and operating system services are used to transmit the message on the network.

For example, when a [redacted] computer communicates with a telemetry device, the telemetry device's IP address is retrieved from the [redacted] computer RWHAT database, the [redacted] Network messages are created, and the [redacted] Windows operating system sends the messages to the telemetry device.

RWHAT?

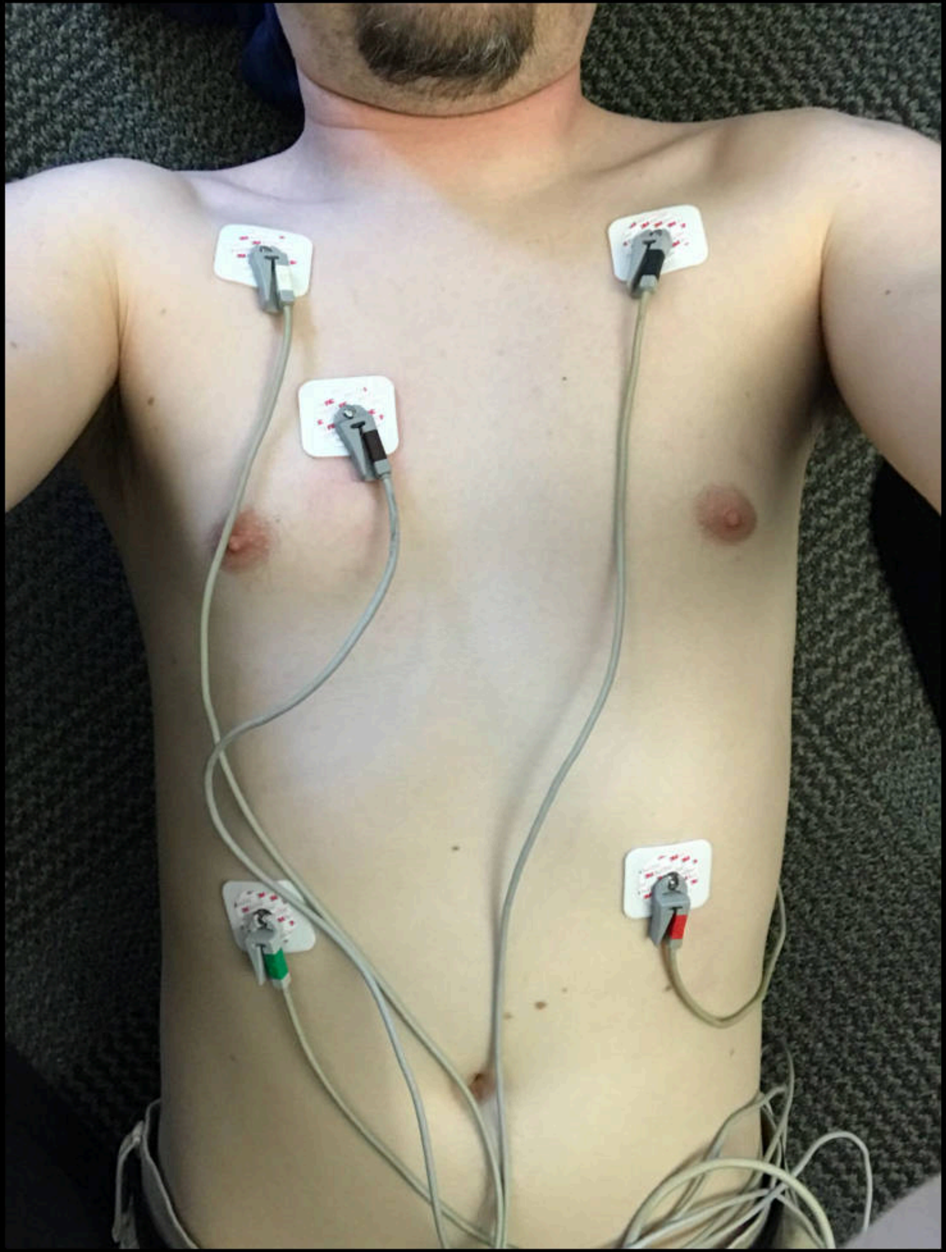
RWHAT packets

All monitoring devices on the [redacted] Network periodically broadcast information about themselves in "RWHAT" packets. Among other things, RWHAT packets contain IP address, port number, name, and offered services information about each device.

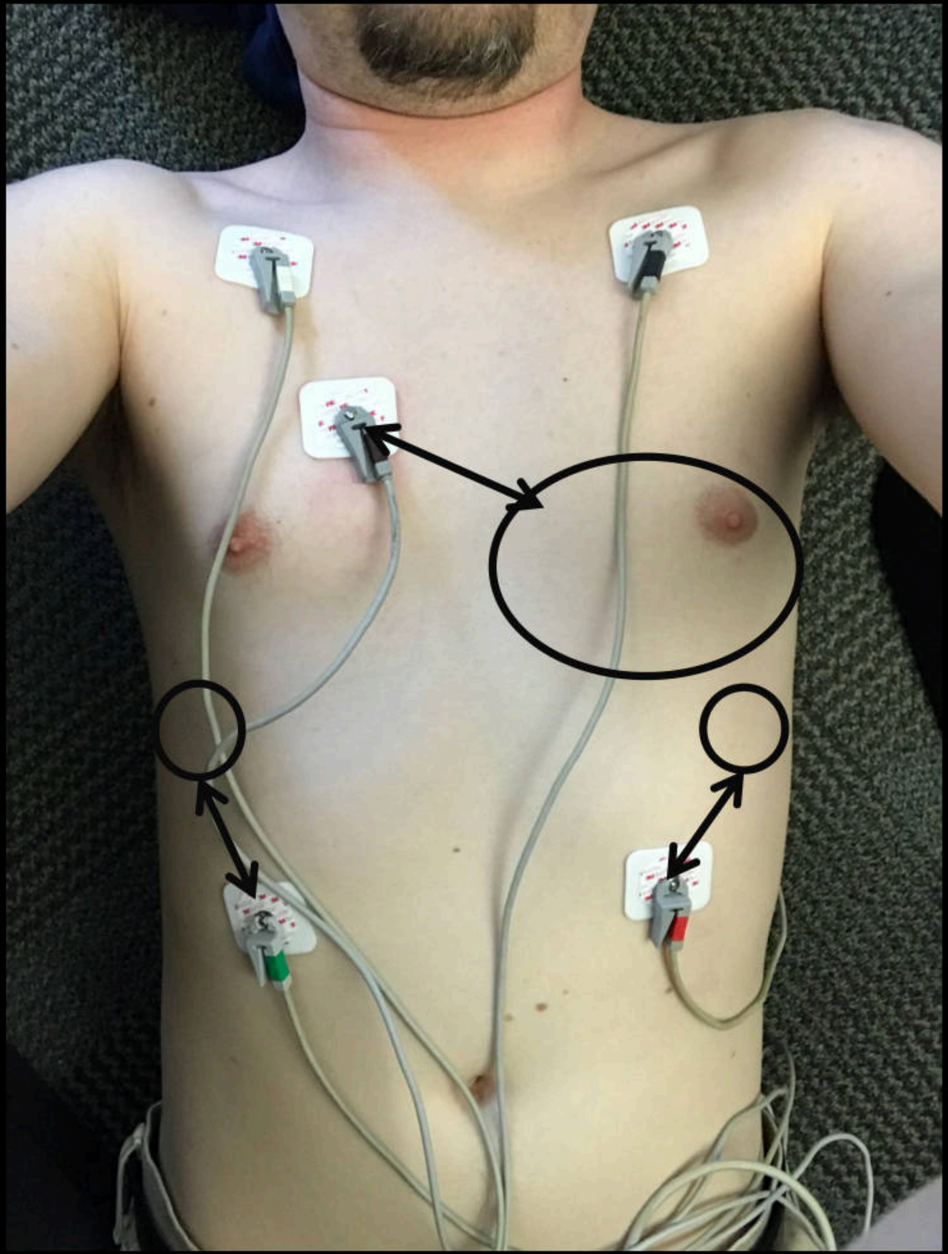
For example, when a [redacted] computer communicates with a telemetry device, the telemetry device's IP address is retrieved from the [redacted] computer RWHAT database, the [redacted] Network messages are created, and the [redacted] Windows operating system sends the messages to the telemetry device.

TESTING SETUP

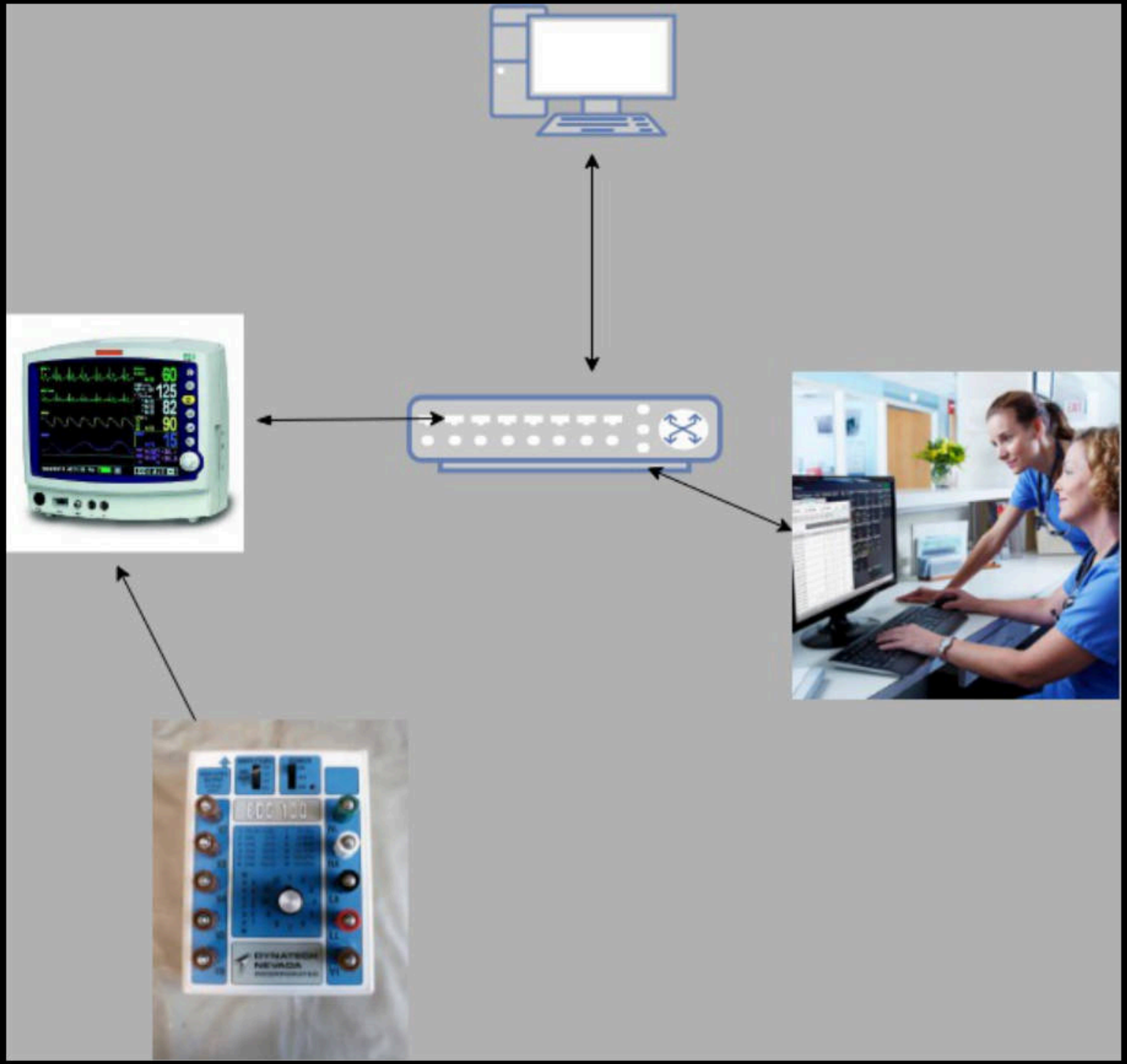
TESTING SETUP



TESTING SETUP



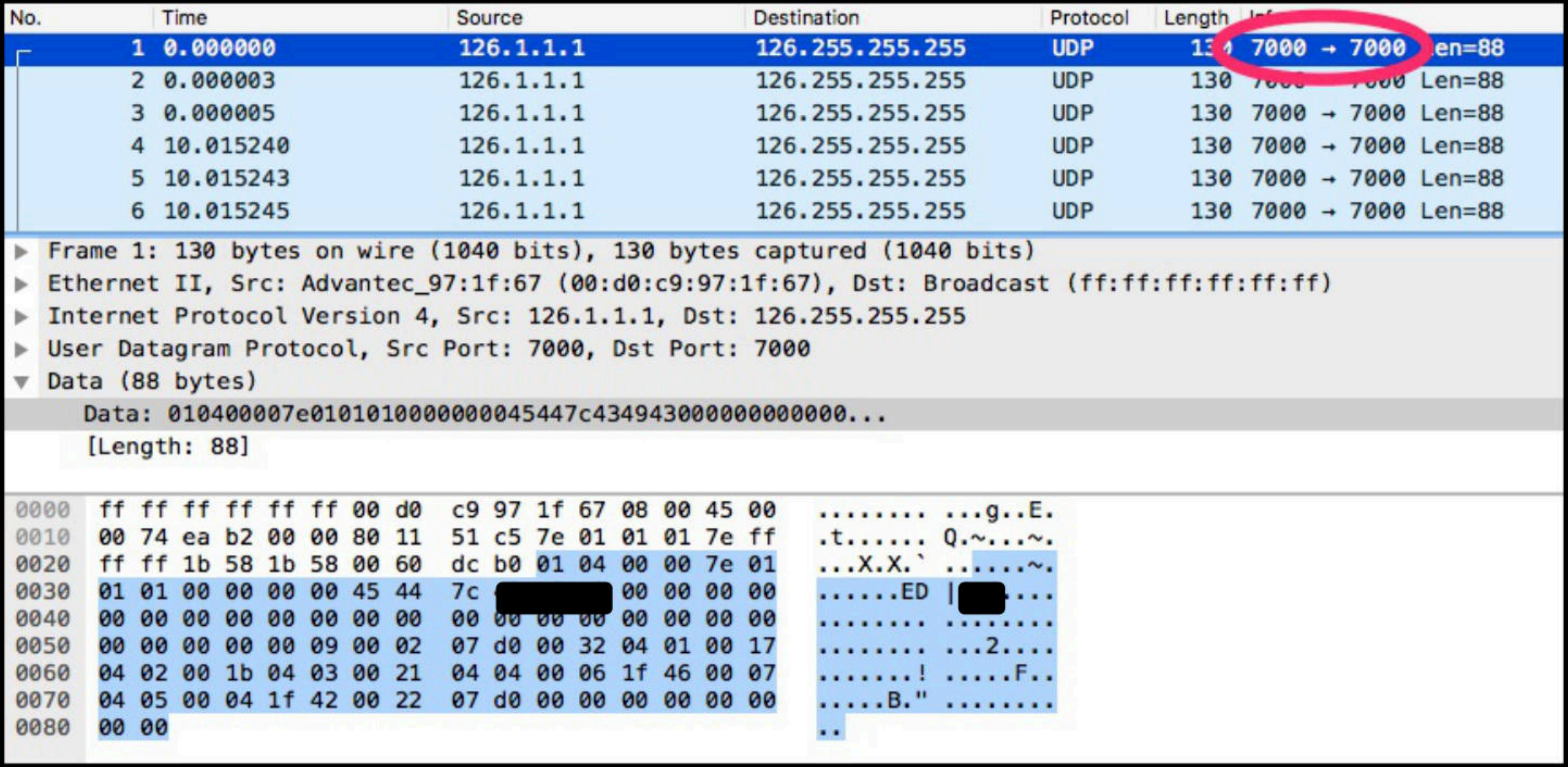
IMPROVED TESTING SETUP



CMS IDLE PACKETS

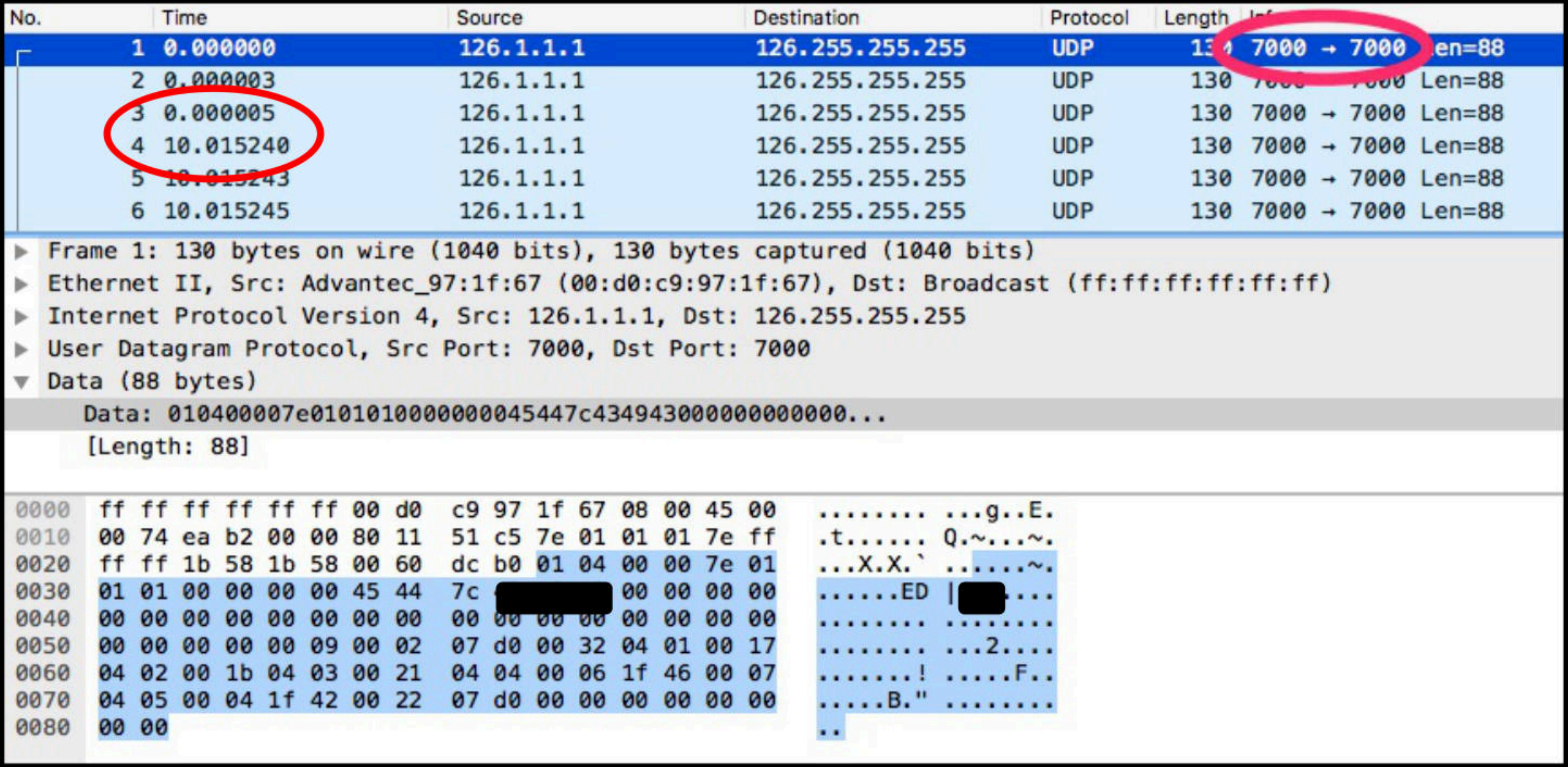
CMS IDLE PACKETS

- CMS BROADCAST PORT



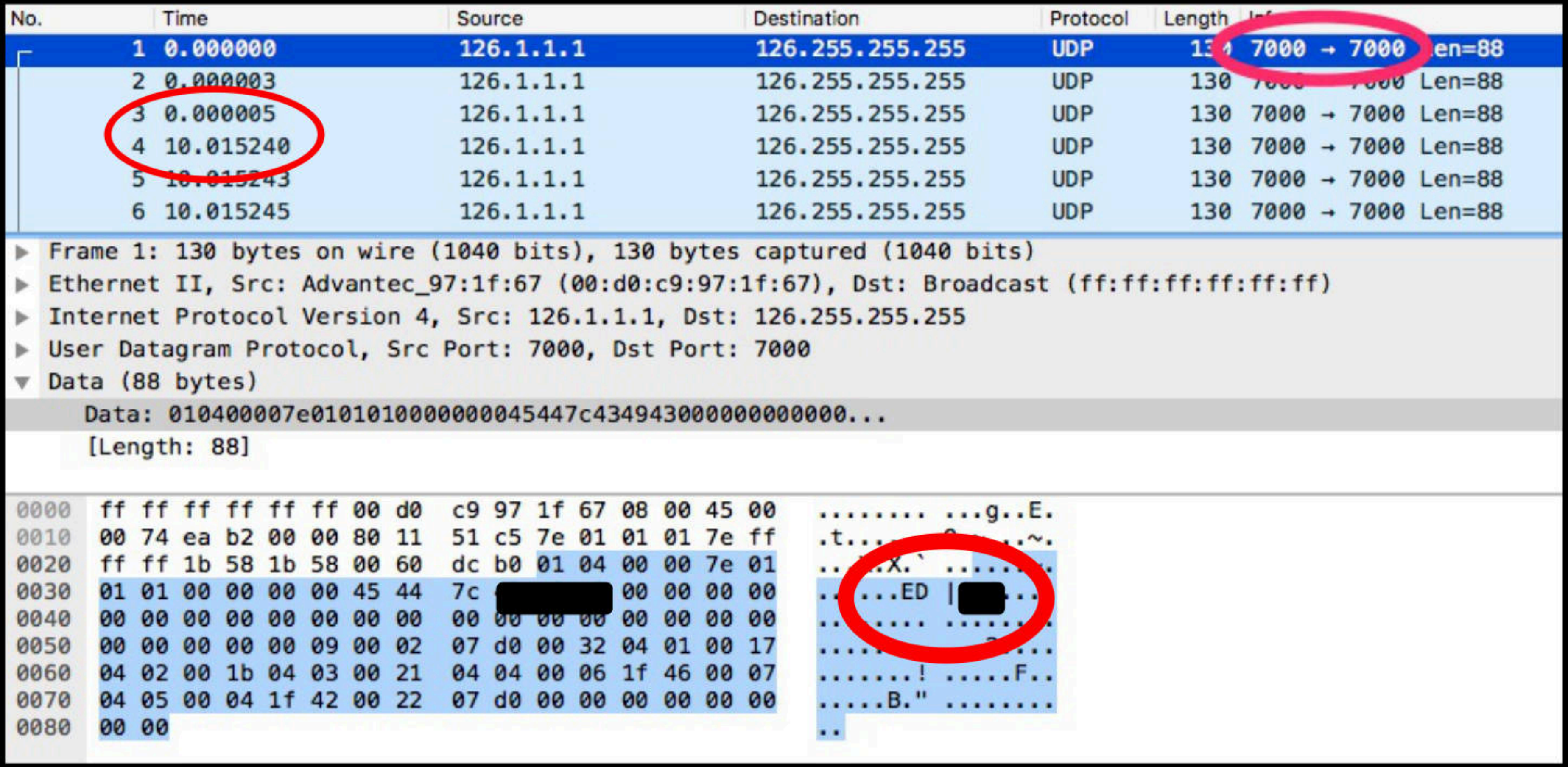
CMS IDLE PACKETS

- CMS BROADCAST PORT
- EVERY 10 SECONDS



CMS IDLE PACKETS

- CMS broadcast port
- Every 10 seconds
- Identifies name



CMS IDLE PACKETS

```
while ( GetExitCodeThread(hThread, &ExitCode) != 1 || ExitCode == 259 )
{
  error = BroadcastRwhat(socket, destPortNum);
  if ( error == -1 || !error )
  {
    winErrorCode = (const wchar_t *)WSAGetLastError();
    swprintf(&String, (size_t)L"BroadcastRwhat() failed (Err = %d).", winErrorCode);
    wprintf(L"%s\n", &String);
    HIDWORD(v5) = &String;
    LODWORD(v5) = 0;
    log(v5);
    break;
  }
  SecondsToWait = GetRwhatPeriod();
  wprintf(L"*** RWHAT PERIOD = %d seconds. ***\n", SecondsToWait);
  age_rwhat(3 * SecondsToWait);
  Sleep(1000 * SecondsToWait);
  if ( dword_405198 > 0 )
    break;
}
```

CMS IDLE PACKETS

```
while ( GetExitCodeThread(hThread, &ExitCode) != 1 || ExitCode == 259 )
{
  error = BroadcastRwhat(socket, destPortNum);
  if ( error == -1 || !error )
  {
    winErrorCode = (const wchar_t *)WSAGetLastError();
    swprintf(&String, (size_t)L"BroadcastRwhat() failed (Err = %d).", winErrorCode);
    wprintf(L"%s\n", &String);
    HIDWORD(v5) = &String;
    LODWORD(v5) = 0;
    log(v5);
    break;
  }
  SecondsToWait = GetRwhatPeriod();
  wprintf(L"*** RWHAT PERIOD = %d seconds. ***\n", SecondsToWait);
  age_rwhat(3 * SecondsToWait);
  Sleep(1000 * SecondsToWait);
  if ( dword_405198 > 0 )
    break;
}
```

CMS IDLE PACKETS

```
int __usercall GetRwhatPeriod@<eax>(wchar_t *a1@<ebp>)
{
  signed int TimeConfigValue; // esi

  WaitForSingleObjectCIC(a1, dword_67A7893C, 0xFFFFFFFF, "rwhatutil.cpp", 419);
  TimeConfigValue = *(_DWORD *)Mapped_RWHT_DB;
  ReleaseMutex(dword_67A7893C);
  if ( TimeConfigValue < 100 )
    return 10;
  if ( TimeConfigValue < 150 )
    return 15;
  if ( TimeConfigValue >= 200 )
    return TimeConfigValue >= 250 ? 28 : 25;
  return 20;
}
```

```
  while ( G
  {
    error =
    if ( er
    {
      winEr
      swpri
      wprin
      HIDWO
      LODWO
      log(v
      break
    }
    SecondsToWait = GetRwhatPeriod();
    wprintf(L"*** RWHAT PERIOD = %d seconds. ***\n", SecondsToWait);
    age_rwhat(3 * SecondsToWait);
    Sleep(1000 * SecondsToWait);
    if ( dword_405198 > 0 )
      break;
  }
```

CMS IDLE PACKETS

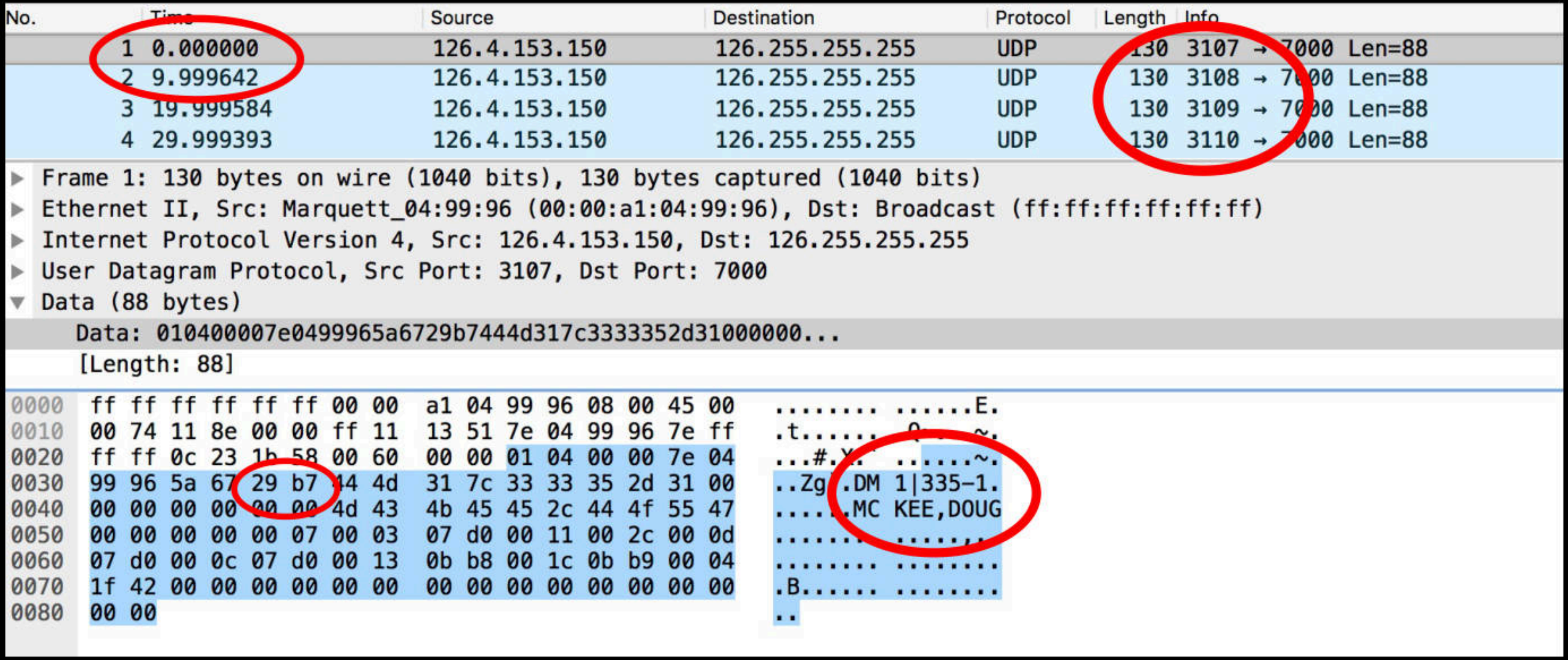
```
int __usercall GetRwhatPeriod@<eax>(wchar_t *a1@<ebp>)
{
  signed int TimeConfigValue; // esi

  WaitForSingleObjectCIC(a1, dword_67A7893C, 0xFFFFFFFF, "rwhatutil.cpp", 419);
  TimeConfigValue = *(_DWORD *)Mapped_RWHT_DB;
  ReleaseMutex(dword_67A7893C);
  if ( TimeConfigValue < 100 )
    return 10;
  if ( TimeConfigValue < 150 )
    return 15;
  if ( TimeConfigValue >= 200 )
    return TimeConfigValue >= 250 ? 28 : 25;
  return 20;
}
```

```
  while ( G
  {
    error =
    if ( er
    {
      winEr
      swpri
      wprin
      HIDWO
      LODWO
      log(v
      break
    }
    SecondsToWait = GetRwhatPeriod();
    wprintf(L"*** RWHAT PERIOD = %d seconds. ***\n", SecondsToWait);
    age_rwhat(3 * SecondsToWait);
    Sleep(1000 * SecondsToWait);
    if ( dword_405198 > 0 )
      break;
  }
```

PM IDLE/BROADCAST PACKETS

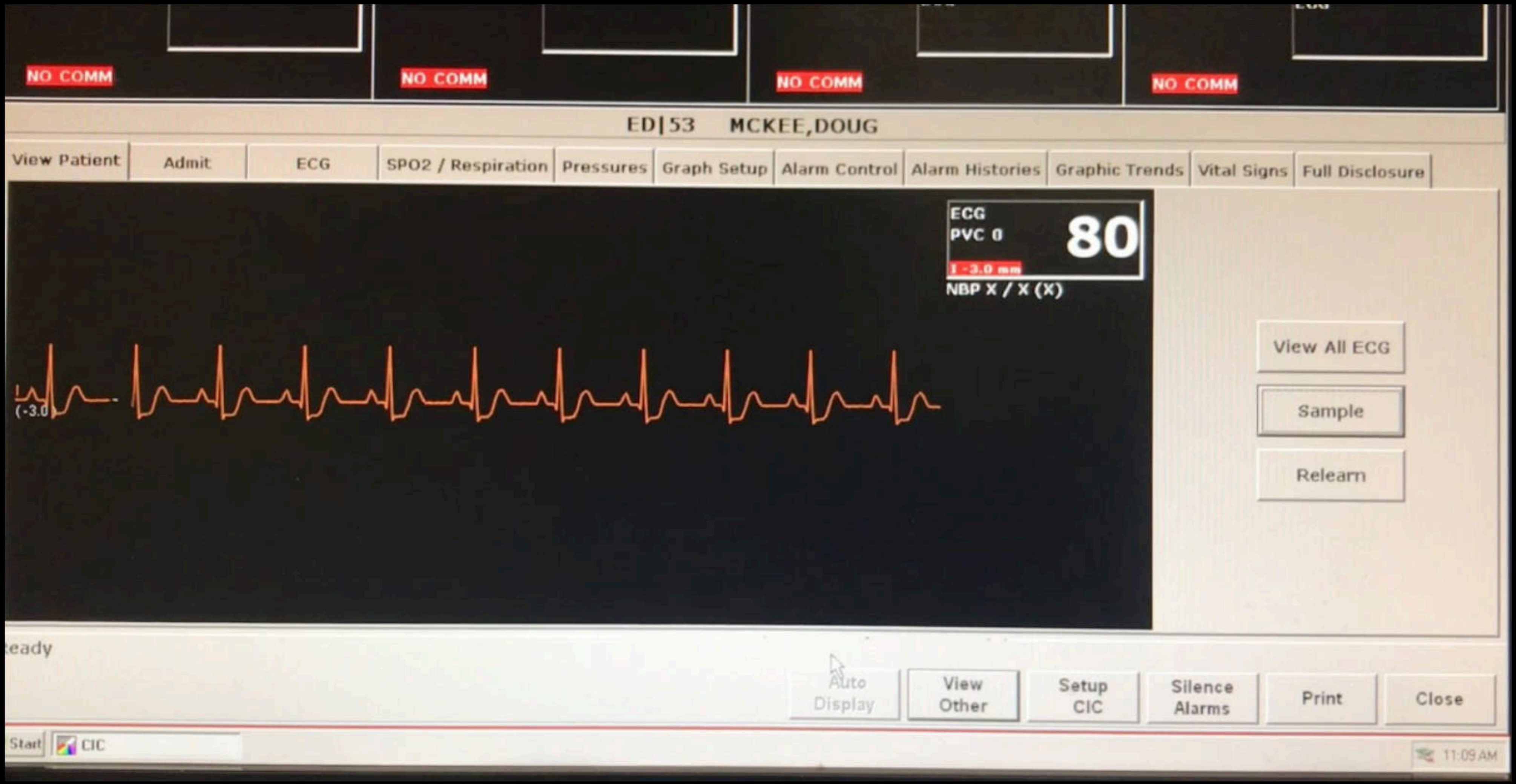
- Every 10 seconds
- Src Ports increment
- Counter by 0xA
- Patient Info



PM IDLE/BROADCAST PACKETS

```
  PatientNameAndBedName = (unsigned __int16 *)((char *)payload + 12);
  v8 = (unsigned __int16 *)v6;
  v9 = wcslen((const wchar_t *)payload + 6);
  if ( v9 < 32 )
    fill((unsigned __int16 *)payload + v9 + 6, 32 - v9, 0);
  parse_logical_name(PatientNameAndBedName, 0x20u, &PatientName, &UnitName);
  a1 = wcscpy;                                         // nonsense
  if ( !PatientName )
  {
    wcscpy(&PatientName, noname);
    v19 = 0;
    if ( UnitName )
      goto LABEL_10;
    goto LABEL_9;
  }
  if ( !UnitName )
  {
LABEL_9:
    wcscpy(&UnitName, nounit);
    v17 = 0;
LABEL_10:
    logicalName = (wchar_t *(__cdecl *)(wchar_t *, const wchar_t *))make_logical_name(&UnitName, &PatientName);
```

CMS – NORMAL OPERATION WITH ECG SIMULATOR



CMS – NORMAL OPERATION WITH ECG SIMULATOR

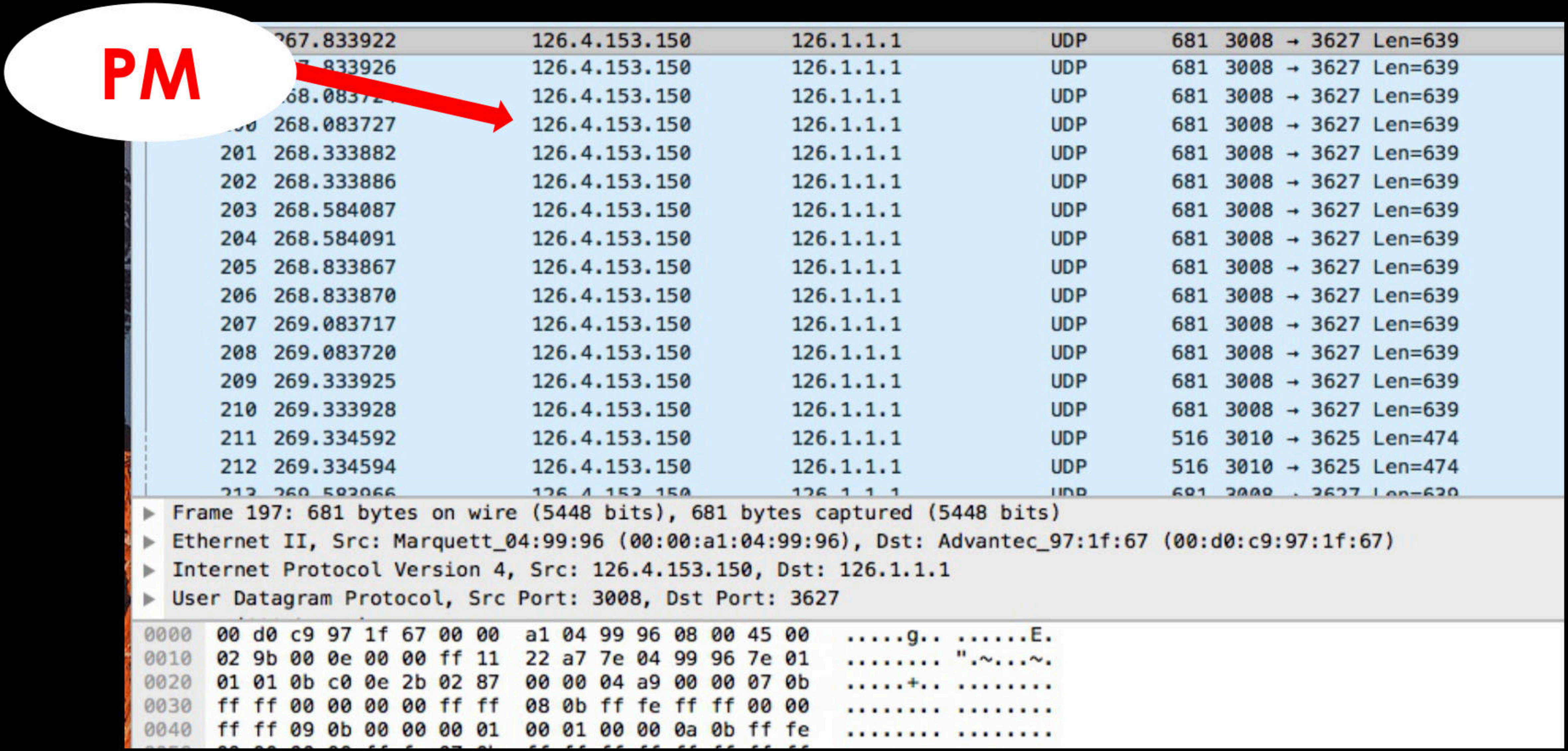
NORMAL TRAFFIC

197	267.833922	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639
198	267.833926	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639
199	268.083724	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639
200	268.083727	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639
201	268.333882	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639
202	268.333886	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639
203	268.584087	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639
204	268.584091	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639
205	268.833867	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639
206	268.833870	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639
207	269.083717	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639
208	269.083720	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639
209	269.333925	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639
210	269.333928	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639
211	269.334592	126.4.153.150	126.1.1.1	UDP	516	3010 → 3625 Len=474
212	269.334594	126.4.153.150	126.1.1.1	UDP	516	3010 → 3625 Len=474

▶ Frame 197: 681 bytes on wire (5448 bits), 681 bytes captured (5448 bits)
▶ Ethernet II, Src: Marquett_04:99:96 (00:00:a1:04:99:96), Dst: Advantec_97:1f:67 (00:d0:c9:97:1f:67)
▶ Internet Protocol Version 4, Src: 126.4.153.150, Dst: 126.1.1.1
▶ User Datagram Protocol, Src Port: 3008, Dst Port: 3627

```
0000  00 d0 c9 97 1f 67 00 00  a1 04 99 96 08 00 45 00   .....g.. ......E.
0010  02 9b 00 0e 00 00 ff 11  22 a7 7e 04 99 96 7e 01   ........ ".~...~.
0020  01 01 0b c0 0e 2b 02 87  00 00 04 a9 00 00 07 0b   .....+.. ........
0030  ff ff 00 00 00 00 ff ff  08 0b ff fe ff ff 00 00   ........ ........
0040  ff ff 09 0b 00 00 00 01  00 01 00 00 0a 0b ff fe   ........ ........
```

NORMAL TRAFFIC



NORMAL TRAFFIC

PM

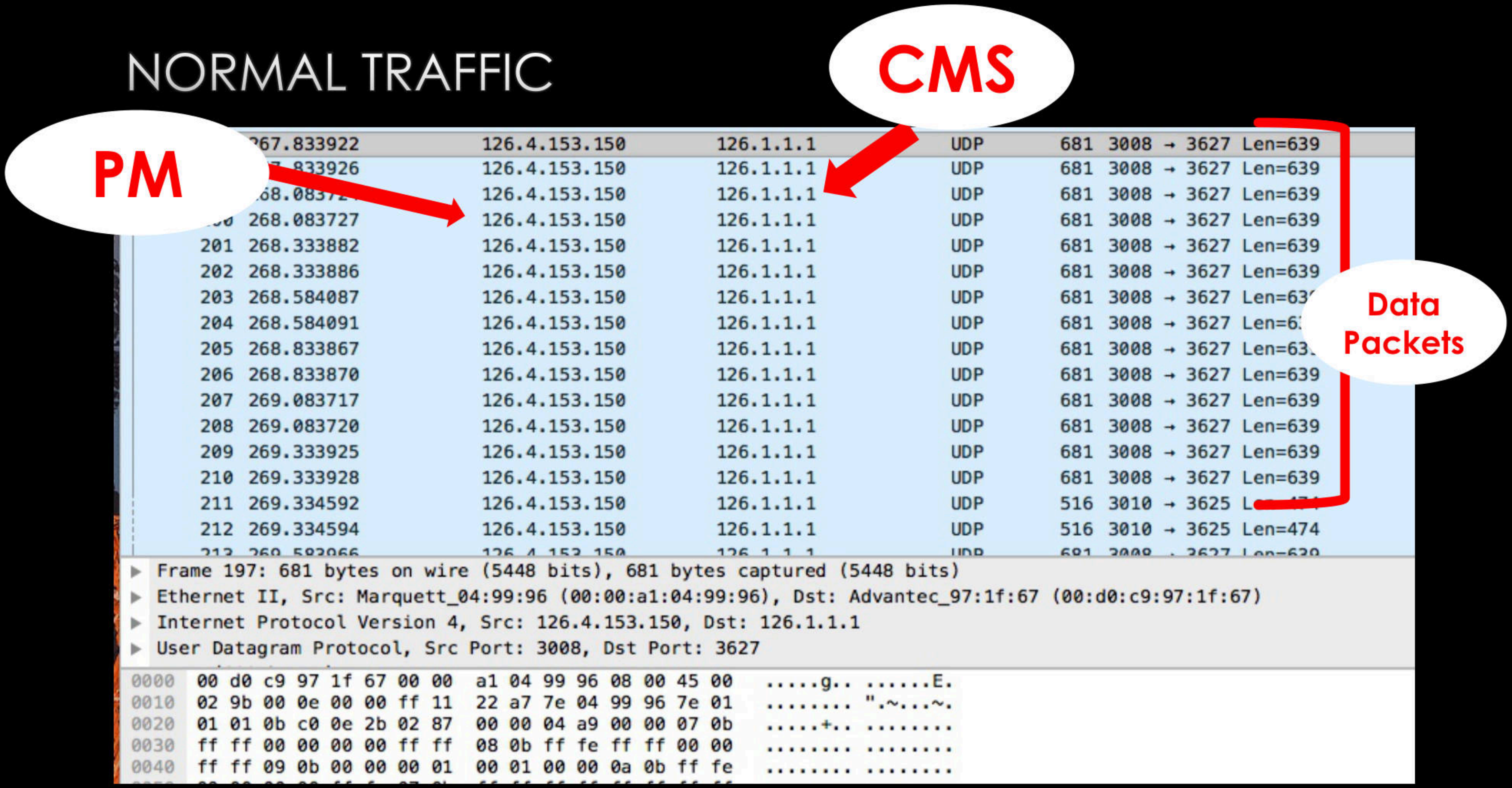
CMS

No.	Time	Source	Destination	Protocol	Length	Info
[illegible]	267.833922	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639
[illegible]	267.833926	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639
[illegible]	268.08372[illegible]	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639
[illegible]	268.083727	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639
201	268.333882	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639
202	268.333886	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639
203	268.584087	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639
204	268.584091	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639
205	268.833867	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639
206	268.833870	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639
207	269.083717	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639
208	269.083720	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639
209	269.333925	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639
210	269.333928	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639
211	269.334592	126.4.153.150	126.1.1.1	UDP	516	3010 → 3625 Len=474
212	269.334594	126.4.153.150	126.1.1.1	UDP	516	3010 → 3625 Len=474
213	269.583966	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639

```
▶ Frame 197: 681 bytes on wire (5448 bits), 681 bytes captured (5448 bits)
▶ Ethernet II, Src: Marquett_04:99:96 (00:00:a1:04:99:96), Dst: Advantec_97:1f:67 (00:d0:c9:97:1f:67)
▶ Internet Protocol Version 4, Src: 126.4.153.150, Dst: 126.1.1.1
▶ User Datagram Protocol, Src Port: 3008, Dst Port: 3627
```

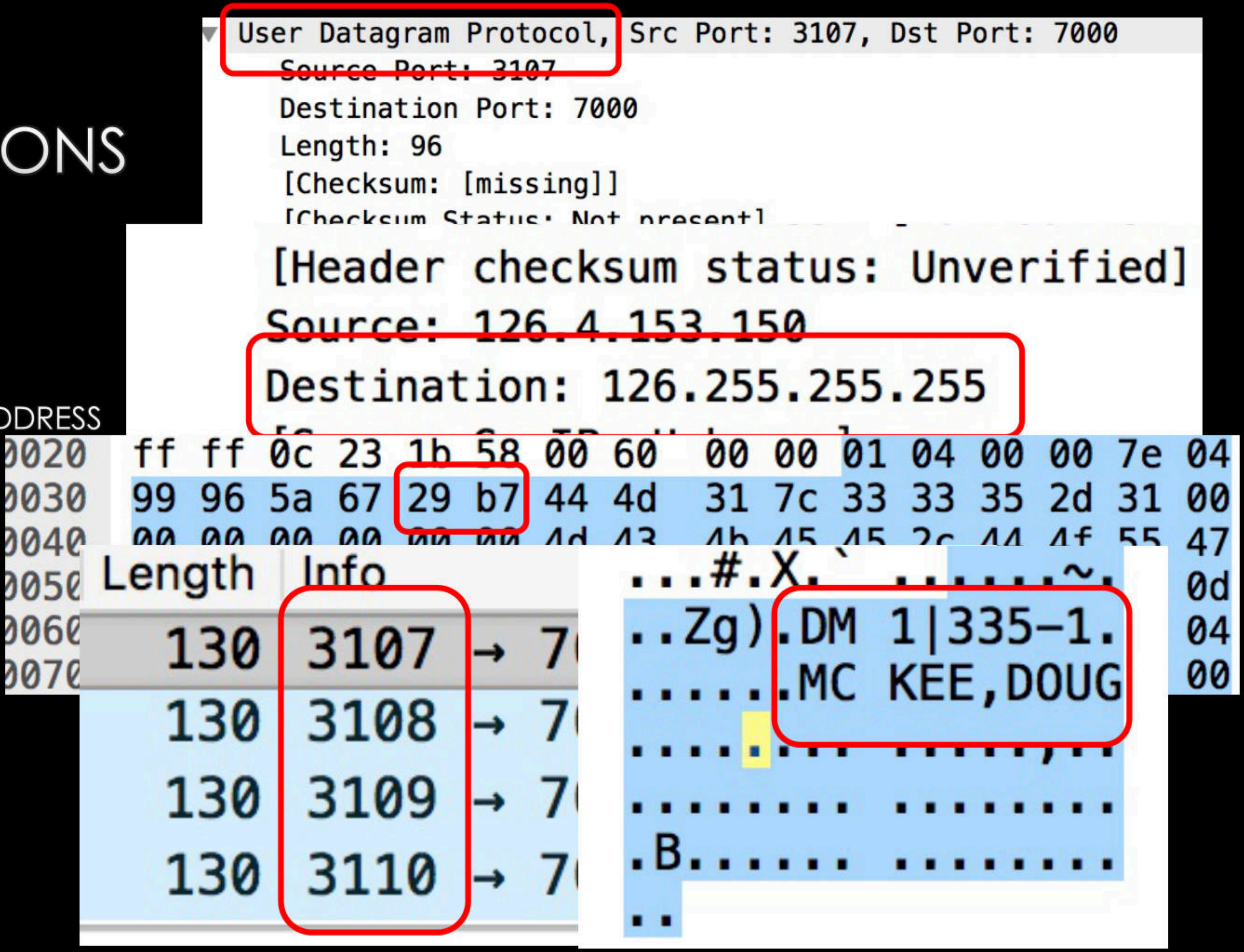
```
0000  00 d0 c9 97 1f 67 00 00  a1 04 99 96 08 00 45 00   .....g.. ......E.
0010  02 9b 00 0e 00 00 ff 11  22 a7 7e 04 99 96 7e 01   ........ ".~...~.
0020  01 01 0b c0 0e 2b 02 87  00 00 04 a9 00 00 07 0b   .....+.. ........
0030  ff ff 00 00 00 00 ff ff  08 0b ff fe ff ff 00 00   ........ ........
0040  ff ff 09 0b 00 00 00 01  00 01 00 00 0a 0b ff fe   ........ ........
```

NORMAL TRAFFIC



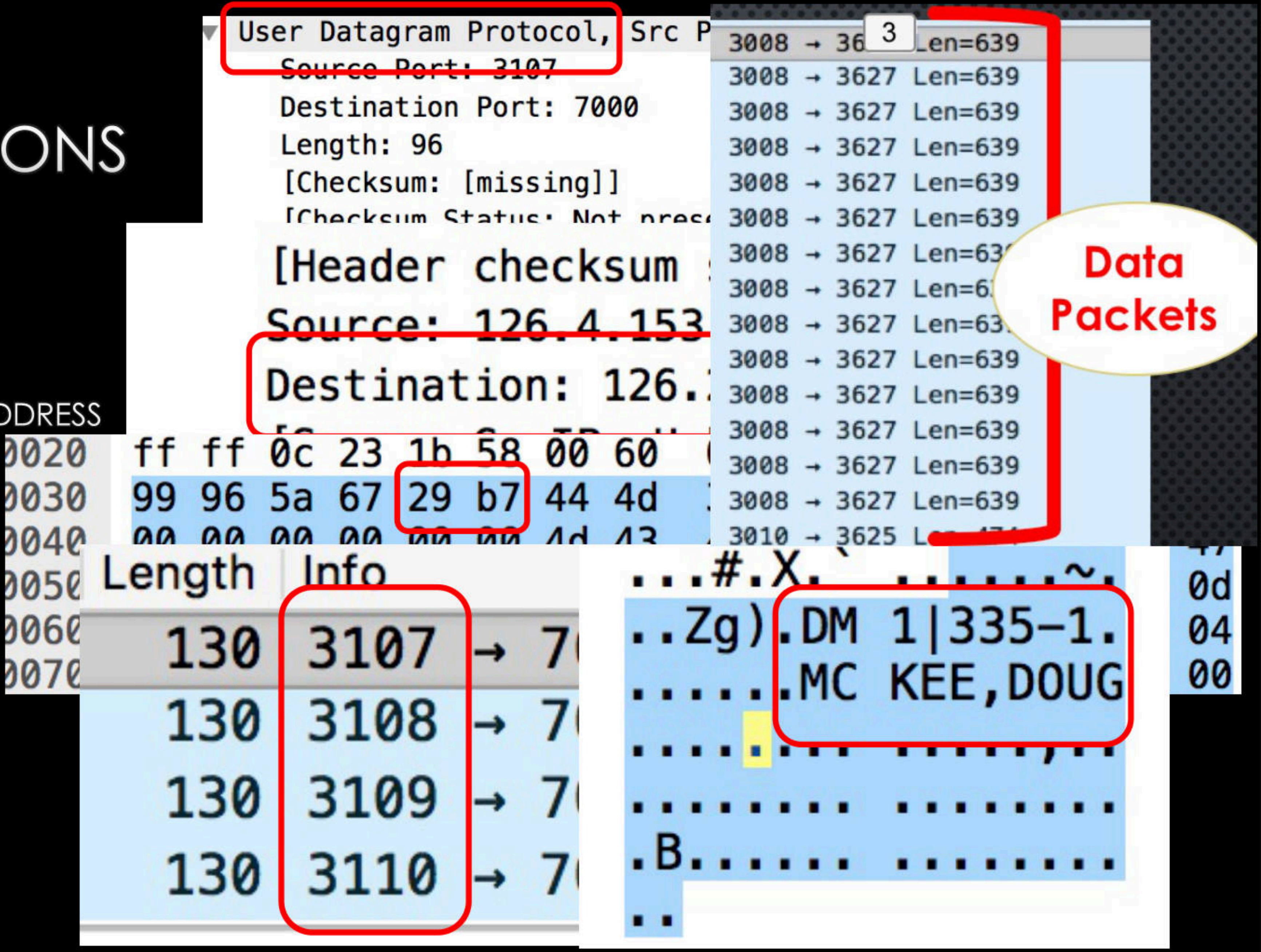
BASIC OBSERVATIONS

- UDP Packets
- Utilization of Broadcast address
- Counters
- Varying Port numbers
- Not encrypted



BASIC OBSERVATIONS

- UDP Packets
- Utilization of Broadcast address
- Counters
- Varying Port numbers
- Not encrypted
- Data Packets



BASIC OBSERVATIONS

- UDP Packets
- Utilization of Broadcast address
- Counters
- Varying Port numbers
- Not encrypted
- Data Packets

- Replay attack ?

SIMPLE REPLAY!!!!

SIMPLE REPLAY!!!!

UNDERSTANDING THE PACKETS: HANDSHAKE

UNDERSTANDING THE PACKETS: HANDSHAKE

173	260.261351	126.1.1.1	126.255.255.255	UDP	130	7000 → 7000 Len=88
174	260.261353	126.1.1.1	126.255.255.255	UDP	130	7000 → 7000 Len=88
183	263.893005	126.1.1.1	126.4.153.150	UDP	104	3625 → 2000 Len=62
184	263.893007	126.1.1.1	126.4.153.150	UDP	104	3625 → 2000 Len=62
185	265.318585	126.4.153.150	126.255.255.255	UDP	130	3015 → 7000 Len=88
186	265.318588	126.4.153.150	126.255.255.255	UDP	130	3015 → 7000 Len=88
187	265.318590	126.4.153.150	126.255.255.255	UDP	130	3015 → 7000 Len=88
188	265.318592	126.4.153.150	126.255.255.255	UDP	130	3015 → 7000 Len=88
189	265.334402	126.4.153.150	126.1.1.1	UDP	516	3010 → 3625 Len=474
190	265.334405	126.4.153.150	126.1.1.1	UDP	516	3010 → 3625 Len=474
191	265.381835	126.1.1.1	126.4.153.150	UDP	104	3626 → 2000 Len=62
192	265.381838	126.1.1.1	126.4.153.150	UDP	104	3626 → 2000 Len=62
193	267.334357	126.4.153.150	126.1.1.1	UDP	516	3010 → 3625 Len=474
194	267.334360	126.4.153.150	126.1.1.1	UDP	516	3010 → 3625 Len=474
195	267.421811	126.1.1.1	126.4.153.150	UDP	104	3627 → 2000 Len=62
196	267.421813	126.1.1.1	126.4.153.150	UDP	104	3627 → 2000 Len=62
197	267.833922	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639
198	267.833926	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639

UNDERSTANDING THE PACKETS: HANDSHAKE

173	260.261351	126.1.1.1	126.255.255.255	UDP	130	7000 → 7000 Len=88
174	260.261353	126.1.1.1	126.255.255.255	UDP	130	7000 → 7000 Len=88
183	263.893005	126.1.1.1	126.4.153.150	UDP	104	3625 → 2000 Len=62
184	263.893007	126.1.1.1	126.4.153.150	UDP	104	3625 → 2000 Len=62
185	265.318585	126.4.153.150	126.255.255.255	UDP	130	3015 → 7000 Len=88
186	265.318588	126.4.153.150	126.255.255.255	UDP	130	3015 → 7000 Len=88
187	265.318590	126.4.153.150	126.255.255.255	UDP	130	3015 → 7000 Len=88
188	265.318592	126.4.153.150	126.255.255.255	UDP	130	3015 → 7000 Len=88
189	265.334402	126.4.153.150	126.1.1.1	UDP	516	3010 → 3625 Len=474
190	265.334405	126.4.153.150	126.1.1.1	UDP	516	3010 → 3625 Len=474
191	265.381835	126.1.1.1	126.4.153.150	UDP	104	3626 → 2000 Len=62
192	265.381838	126.1.1.1	126.4.153.150	UDP	104	3626 → 2000 Len=62
193	267.334357	126.4.153.150	126.1.1.1	UDP	516	3010 → 3625 Len=474
194	267.334360	126.4.153.150	126.1.1.1	UDP	516	3010 → 3625 Len=474
195	267.421811	126.1.1.1	126.4.153.150	UDP	104	3627 → 2000 Len=62
196	267.421813	126.1.1.1	126.4.153.150	UDP	104	3627 → 2000 Len=62
197	267.833922	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639
198	267.833926	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639

CMS Opens Channel “SYN”

UNDERSTANDING THE PACKETS: HANDSHAKE

173	260.261351	126.1.1.1	126.255.255.255	UDP	130	7000 → 7000 Len=88
174	260.261353	126.1.1.1	126.255.255.255	UDP	130	7000 → 7000 Len=88
183	263.893005	126.1.1.1	126.4.153.150	UDP	104	3625 → 2000 Len=62
184	263.893007	126.1.1.1	126.4.153.150	UDP	104	3625 → 2000 Len=62
185	265.318585	126.4.153.150	126.255.255.255	UDP	130	3015 → 7000 Len=88
186	265.318588	126.4.153.150	126.255.255.255	UDP	130	3015 → 7000 Len=88
187	265.318590	126.4.153.150	126.255.255.255	UDP	130	3015 → 7000 Len=88
188	265.318592	126.4.153.150	126.255.255.255	UDP	130	3015 → 7000 Len=88
189	265.334402	126.4.153.150	126.1.1.1	UDP	516	3010 → 3625 Len=474
190	265.334405	126.4.153.150	126.1.1.1	UDP	516	3010 → 3625 Len=474
191	265.381835	126.1.1.1	126.4.153.150	UDP	104	3626 → 2000 Len=62
192	265.381838	126.1.1.1	126.4.153.150	UDP	104	3626 → 2000 Len=62
193	267.334357	126.4.153.150	126.1.1.1	UDP	516	3010 → 3625 Len=474
194	267.334360	126.4.153.150	126.1.1.1	UDP	516	3010 → 3625 Len=474
195	267.421811	126.1.1.1	126.4.153.150	UDP	104	3627 → 2000 Len=62
196	267.421813	126.1.1.1	126.4.153.150	UDP	104	3627 → 2000 Len=62
197	267.833922	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639
198	267.833926	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639

CMS Opens Channel “SYN”

PM “SYN, ACK”

UNDERSTANDING THE PACKETS: HANDSHAKE

173	260.261351	126.1.1.1	126.255.255.255	UDP	130	7000 → 7000 Len=88
174	260.261353	126.1.1.1	126.255.255.255	UDP	130	7000 → 7000 Len=88
183	263.893005	126.1.1.1	126.4.153.150	UDP	104	3625 → 2000 Len=62
184	263.893007	126.1.1.1	126.4.153.150	UDP	104	3625 → 2000 Len=62
185	265.318585	126.4.153.150	126.255.255.255	UDP	130	3015 → 7000 Len=88
186	265.318588	126.4.153.150	126.255.255.255	UDP	130	3015 → 7000 Len=88
187	265.318590	126.4.153.150	126.255.255.255	UDP	130	3015 → 7000 Len=88
188	265.318592	126.4.153.150	126.255.255.255	UDP	130	3015 → 7000 Len=88
189	265.334402	126.4.153.150	126.1.1.1	UDP	516	3010 → 3625 Len=474
190	265.334405	126.4.153.150	126.1.1.1	UDP	516	3010 → 3625 Len=474
191	265.381835	126.1.1.1	126.4.153.150	UDP	104	3626 → 2000 Len=62
192	265.381838	126.1.1.1	126.4.153.150	UDP	104	3626 → 2000 Len=62
193	267.334357	126.4.153.150	126.1.1.1	UDP	516	3010 → 3625 Len=474
194	267.334360	126.4.153.150	126.1.1.1	UDP	516	3010 → 3625 Len=474
195	267.421811	126.1.1.1	126.4.153.150	UDP	104	3627 → 2000 Len=62
196	267.421813	126.1.1.1	126.4.153.150	UDP	104	3627 → 2000 Len=62
197	267.833922	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639
198	267.833926	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639

CMS Opens Channel "SYN"

PM "SYN, ACK"

UNDERSTANDING THE PACKETS: HANDSHAKE

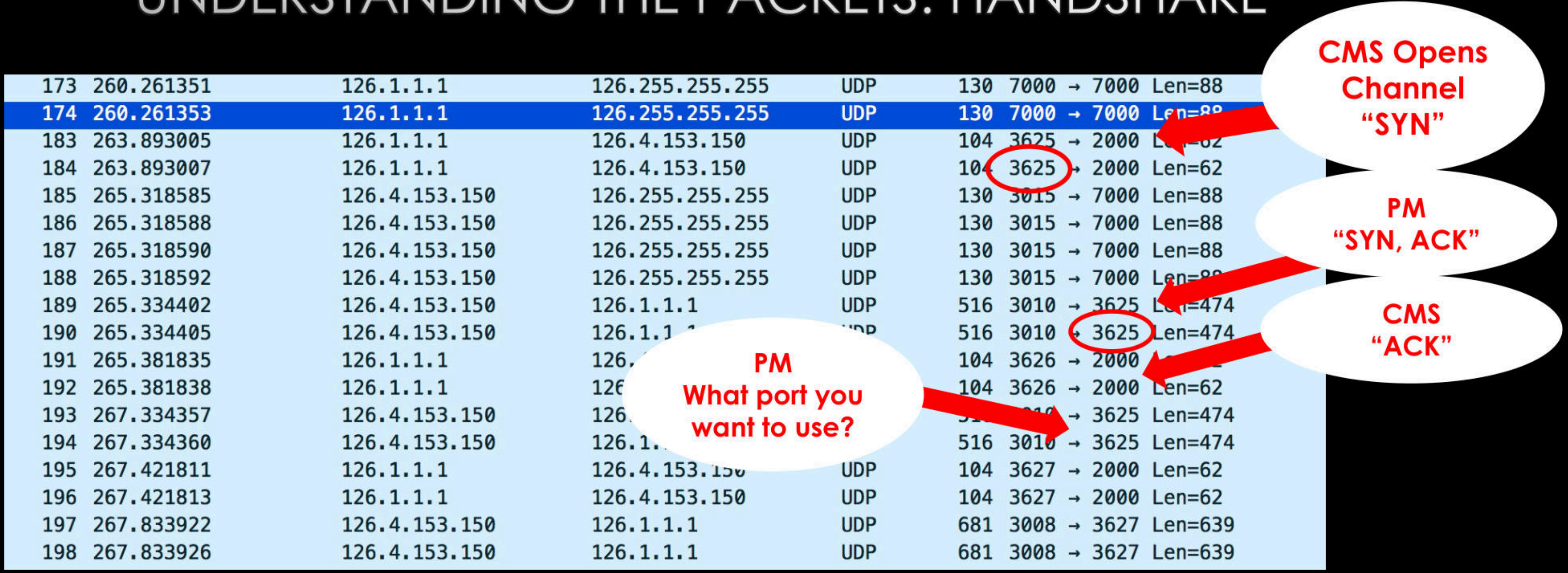
173	260.261351	126.1.1.1	126.255.255.255	UDP	130	7000 → 7000 Len=88
174	260.261353	126.1.1.1	126.255.255.255	UDP	130	7000 → 7000 Len=88
183	263.893005	126.1.1.1	126.4.153.150	UDP	104	3625 → 2000 [illegible]
184	263.893007	126.1.1.1	126.4.153.150	UDP	104	3625 → 2000 Len=62
185	265.318585	126.4.153.150	126.255.255.255	UDP	130	3015 → 7000 Len=88
186	265.318588	126.4.153.150	126.255.255.255	UDP	130	3015 → 7000 Len=88
187	265.318590	126.4.153.150	126.255.255.255	UDP	130	3015 → 7000 Len=88
188	265.318592	126.4.153.150	126.255.255.255	UDP	130	3015 → 7000 [illegible]
189	265.334402	126.4.153.150	126.1.1.1	UDP	516	3010 → 3625 [illegible]
190	265.334405	126.4.153.150	126.1.1.1	UDP	516	3010 → 3625 Len=474
191	265.381835	126.1.1.1	126.4.153.150	UDP	104	3626 → 2000 [illegible]
192	265.381838	126.1.1.1	126.4.153.150	UDP	104	3626 → 2000 Len=62
193	267.334357	126.4.153.150	126.1.1.1	UDP	516	3010 → 3625 Len=474
194	267.334360	126.4.153.150	126.1.1.1	UDP	516	3010 → 3625 Len=474
195	267.421811	126.1.1.1	126.4.153.150	UDP	104	3627 → 2000 Len=62
196	267.421813	126.1.1.1	126.4.153.150	UDP	104	3627 → 2000 Len=62
197	267.833922	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639
198	267.833926	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639

CMS Opens Channel "SYN"

PM "SYN, ACK"

CMS "ACK"

UNDERSTANDING THE PACKETS: HANDSHAKE



173	260.261351	126.1.1.1	126.255.255.255	UDP	130	7000 → 7000 Len=88
174	260.261353	126.1.1.1	126.255.255.255	UDP	130	7000 → 7000 Len=88
183	263.893005	126.1.1.1	126.4.153.150	UDP	104	3625 → 2000 Len=62
184	263.893007	126.1.1.1	126.4.153.150	UDP	104	3625 → 2000 Len=62
185	265.318585	126.4.153.150	126.255.255.255	UDP	130	3015 → 7000 Len=88
186	265.318588	126.4.153.150	126.255.255.255	UDP	130	3015 → 7000 Len=88
187	265.318590	126.4.153.150	126.255.255.255	UDP	130	3015 → 7000 Len=88
188	265.318592	126.4.153.150	126.255.255.255	UDP	130	3015 → 7000 Len=88
189	265.334402	126.4.153.150	126.1.1.1	UDP	516	3010 → 3625 Len=474
190	265.334405	126.4.153.150	126.1.1.1	UDP	516	3010 → 3625 Len=474
191	265.381835	126.1.1.1	[illegible]	[illegible]	104	3626 → 2000 [illegible]
192	265.381838	126.1.1.1	[illegible]	[illegible]	104	3626 → 2000 Len=62
193	267.334357	126.4.153.150	[illegible]	[illegible]	[illegible]	[illegible] → 3625 Len=474
194	267.334360	126.4.153.150	[illegible]	[illegible]	516	3010 → 3625 Len=474
195	267.421811	126.1.1.1	126.4.153.150	UDP	104	3627 → 2000 Len=62
196	267.421813	126.1.1.1	126.4.153.150	UDP	104	3627 → 2000 Len=62
197	267.833922	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639
198	267.833926	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639

UNDERSTANDING THE PACKETS: HANDSHAKE

173	260.261351	126.1.1.1	126.255.255.255	UDP	130	7000 → 7000 Len=88
174	260.261353	126.1.1.1	126.255.255.255	UDP	130	7000 → 7000 Len=88
183	263.893005	126.1.1.1	126.4.153.150	UDP	104	3625 → 2000 [illegible]
184	263.893007	126.1.1.1	126.4.153.150	UDP	104	3625 → 2000 Len=62
185	265.318585	126.4.153.150	126.255.255.255	UDP	130	3015 → 7000 Len=88
186	265.318588	126.4.153.150	126.255.255.255	UDP	130	3015 → 7000 Len=88
187	265.318590	126.4.153.150	126.255.255.255	UDP	130	3015 → 7000 Len=88
188	265.318592	126.4.153.150	126.255.255.255	UDP	130	3015 → 7000 [illegible]
189	265.334402	126.4.153.150	126.1.1.1	UDP	516	3010 → 3625 [illegible]
190	265.334405	126.4.153.150	[illegible]	[illegible]	516	3010 → 3625 Len=474
191	265.381835	126.1.1.1	[illegible]	[illegible]	104	3626 → 2000 [illegible]
192	265.381838	126.1.1.1	[illegible]	[illegible]	104	3626 → 2000 Len=62
193	267.334357	126.4.153.150	[illegible]	[illegible]	[illegible]	[illegible] → 3625 Len=474
194	267.334360	126.4.153.150	[illegible]	[illegible]	516	3010 → 3625 Len=474
195	267.421811	126.1.1.1	[illegible]	UDP	104	3627 → 2000 [illegible]
196	267.421813	126.1.1.1	126.4.153.150	UDP	104	3627 → 2000 Len=62
197	267.833922	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639
198	267.833926	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639

CMS Opens Channel "SYN"

PM "SYN, ACK"

CMS "ACK"

PM What port you want to use?

CMS This one! 3627

UNDERSTANDING THE PACKETS: HANDSHAKE

173	260.261351	126.1.1.1	126.255.255.255	UDP	130	7000 → 7000 Len=88
174	260.261353	126.1.1.1	126.255.255.255	UDP	130	7000 → 7000 Len=88
183	263.893005	126.1.1.1	126.4.153.150	UDP	104	3625 → 2000 [illegible]
184	263.893007	126.1.1.1	126.4.153.150	UDP	104	3625 → 2000 Len=62
185	265.318585	126.4.153.150	126.255.255.255	UDP	130	3015 → 7000 Len=88
186	265.318588	126.4.153.150	126.255.255.255	UDP	130	3015 → 7000 Len=88
187	265.318590	126.4.153.150	126.255.255.255	UDP	130	3015 → 7000 Len=88
188	265.318592	126.4.153.150	126.255.255.255	UDP	130	3015 → 7000 [illegible]
189	265.334402	126.4.153.150	126.1.1.1	UDP	516	3010 → 3625 [illegible]
190	265.334405	126.4.153.150	126.1.1.[illegible]	[illegible]	516	3010 → 3625 Len=474
191	265.381835	126.1.1.1	126.[illegible]	[illegible]	104	3626 → 2000 [illegible]
192	265.381838	126.1.1.1	126[illegible]	[illegible]	104	3626 → 2000 Len=62
193	267.334357	126.4.153.150	126.[illegible]	[illegible]	[illegible]	[illegible] → 3625 Len=474
194	267.334360	126.4.153.150	126.1.[illegible]	[illegible]	516	3010 → 3625 Len=474
195	267.421811	126.1.1.1	126.4.153.150	UDP	104	3627 → 2000 [illegible]
196	267.421813	126.1.1.1	126.4.153.150	UDP	104	3627 → 2000 Len=62
197	267.833922	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639
198	267.833926	126.4.153.150	126.1.1.1	UDP	681	3008 → 3627 Len=639

CMS Opens Channel "SYN"

PM "SYN, ACK"

CMS "ACK"

PM What port you want to use?

CMS This one! 3627

PM Ok, Here some Data!

HANDSHAKE HACKED!!

HANDSHAKE HACKED!!

CLOSER LOOK AT “SYN,ACK” PACKETS

CLOSER LOOK AT "SYN,ACK" PACKETS

173	260.261351	126.1.1.1	126.255.255.255	UDP	130	7000	→	7000	Len=88
174	260.261353	126.1.1.1	126.255.255.255	UDP	130	7000	→	7000	Len=88
183	263.893005	126.1.1.1	126.4.153.150	UDP	104	3625	→	2000	Len=62
184	263.893007	126.1.1.1	126.4.153.150	UDP	104	3625	→	2000	Len=62
185	265.318585	126.4.153.150	126.255.255.255	UDP	130	3015	→	7000	Len=88
186	265.318588	126.4.153.150	126.255.255.255	UDP	130	3015	→	7000	Len=88
187	265.318590	126.4.153.150	126.255.255.255	UDP	130	3015	→	7000	Len=88
188	265.318592	126.4.153.150	126.255.255.255	UDP	130	3015	→	7000	Len=88
189	265.334402	126.4.153.150	126.1.1.1	UDP	516	3010	→	3625	Len=474
190	265.334405	126.4.153.150	126.1.1.1	UDP	516	3010	→	3625	Len=474
191	265.381835	126.1.1.1	126.4.153.150	UDP	104	3626	→	2000	Len=62
192	265.381838	126.1.1.1	126.4.153.150	UDP	104	3626	→	2000	Len=62
193	267.334357	126.4.153.150	126.1.1.1	UDP	516	3010	→	3625	Len=474
194	267.334360	126.4.153.150	126.1.1.1	UDP	516	3010	→	3625	Len=474
195	267.421811	126.1.1.1	126.4.153.150	UDP	104	3627	→	2000	Len=62
196	267.421813	126.1.1.1	126.4.153.150	UDP	104	3627	→	2000	Len=62
197	267.833922	126.4.153.150	126.1.1.1	UDP	681	3008	→	3627	Len=639
198	267.833926	126.4.153.150	126.1.1.1	UDP	681	3008	→	3627	Len=639

CLOSER LOOK AT "SYN,ACK" PACKETS

```
173 260.261351   126.1.1.1      126.255.255.255  UDP  130  7000 → 7000 Len=88
174 260.261353   126.1.1.1      126.255.255.255  UDP  130  7000 → 7000 Len=88

0020  01 01 0b c2 0e 29 01 e2  00 00 7e 04 99 96 00 00   ......)...~.....
0030  7e 04 99 96 00 00 00 c9  00 14 00 01 00 13 00 00   ~...............
0040  00 00 00 00 00 00 00 00  00 00 00 00 00 00 00 00   ................
0050  00 00 00 00 00 00 00 00  00 00 00 00 00 00 00 00   ................
0060  00 00 00 00 01 9e 00 04  00 01 06 00 01 3a c0 00   .............:..
0070  00 50 00 00 00 00 0c 3a  e2 80 80 80 80 80 80 80   .P.....:........
0080  80 80 80 80 03 3a 90 80  00 00 00 28 00 96 00 00   .....:.....(....
0090  00 06 00 00 00 00 00 00  15 3a 00 00 40 21 40 00   .........:..@!@.
00a0  00 00 02 3a 20 05 00 00  40 09 00 04 01 3a 01 00   ...: ...@....:..
00b0  01 18 c0 80 80 00 80 00  80 00 0c 18 80 01 00 00   ................
00c0  00 00 00 00 00 00 00 00  03 18 00 20 00 0f 00 28   ........... ...(

198 267.833926   126.4.153.150  126.1.1.1        UDP  681  3008 → 3627 Len=639
```

EMULATION OR REPLAY ATTACK STEPS

1. Send broadcast packets to allow CMS to detect device
2. Perform handshake
    1. Accounting for port changes and counters
3. Send captured heartbeat packets

EMULATION DEMO

IMPACT SCENARIO

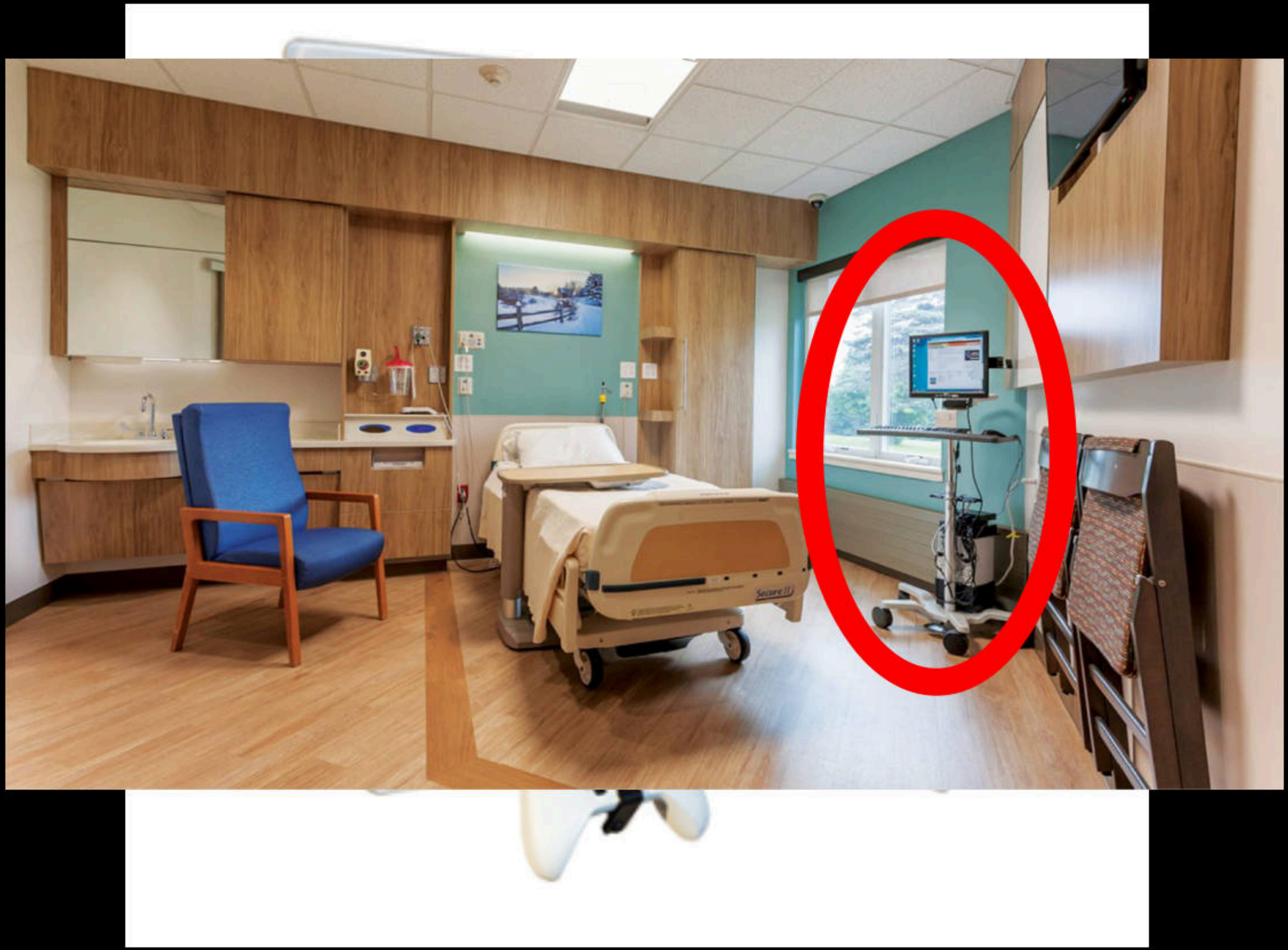
- Loaded onto raspberry pi
- Plug PI into Ethernet jack
- Can harm patient unnoticed

IMPACT SCENARIO

- LOADED ONTO RASPBERRY PI
- PLUG PI INTO ETHERNET JACK
- CAN HARM PATIENT UNNOTICED

IMPACT SCENARIO

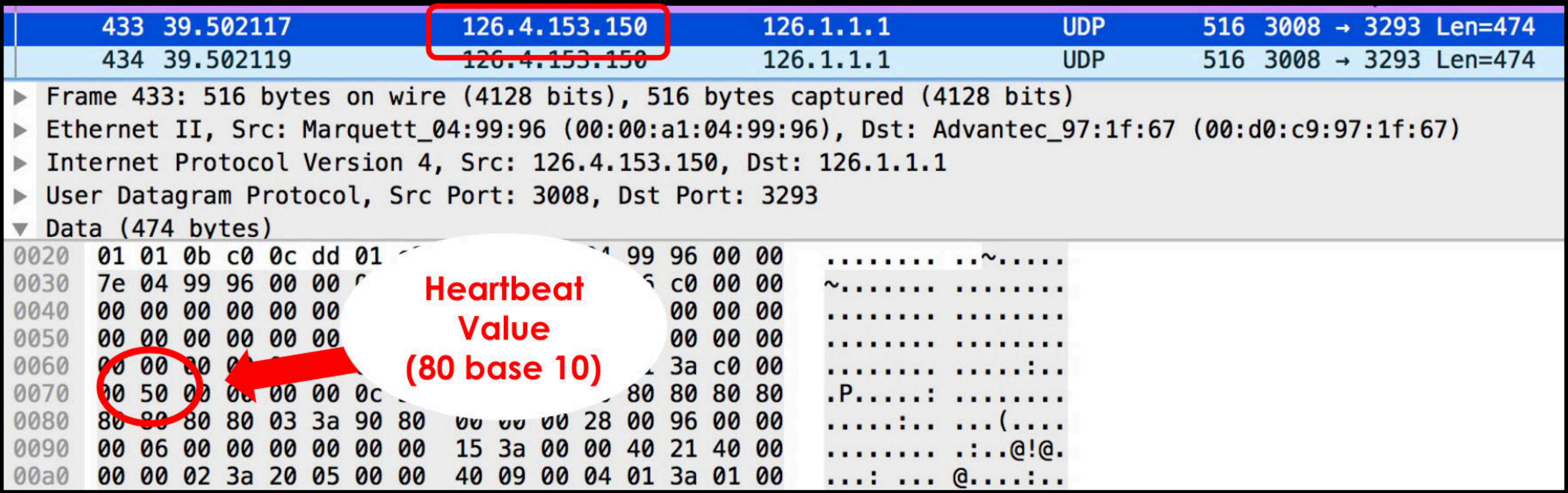
- LOADED ONTO RASPBERRY PI
- PLUG PI INTO ETHERNET JACK
- CAN HARM PATIENT UNNOTICED



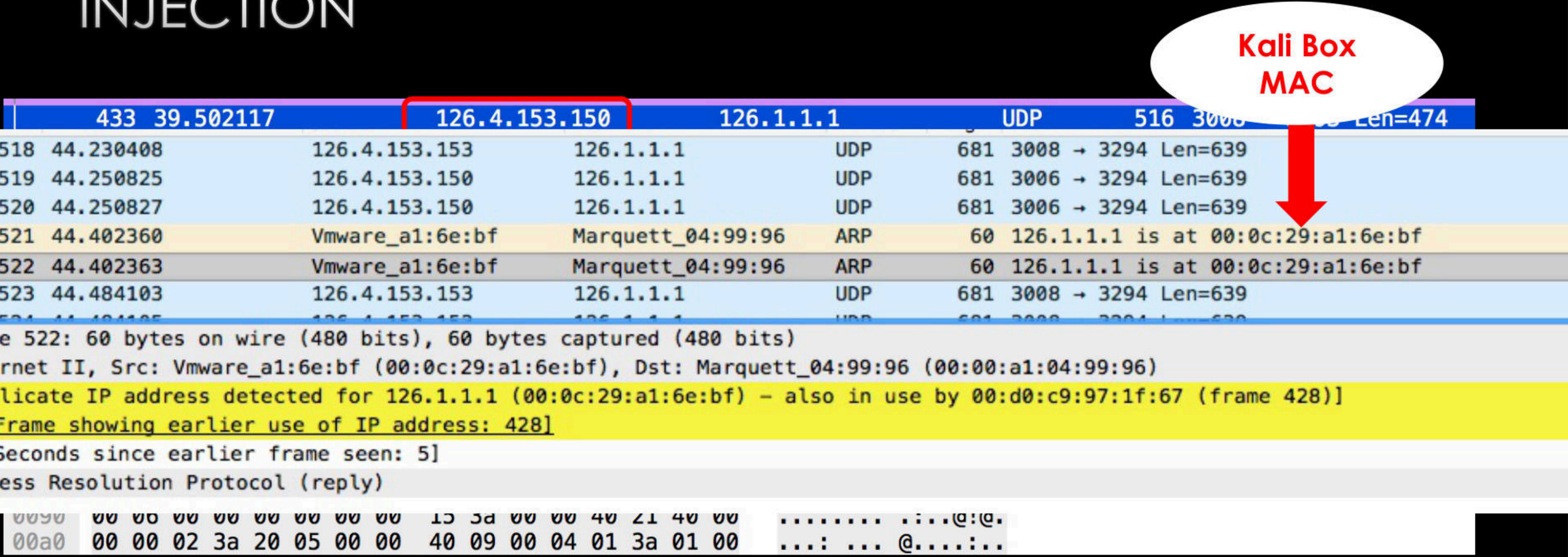
WHAT ABOUT MODIFYING EXISTING DATA?

- Handshake is already completed
- Data port? Respond packet port?
  - Arp Spoof
- Send new data on same port

INJECTION

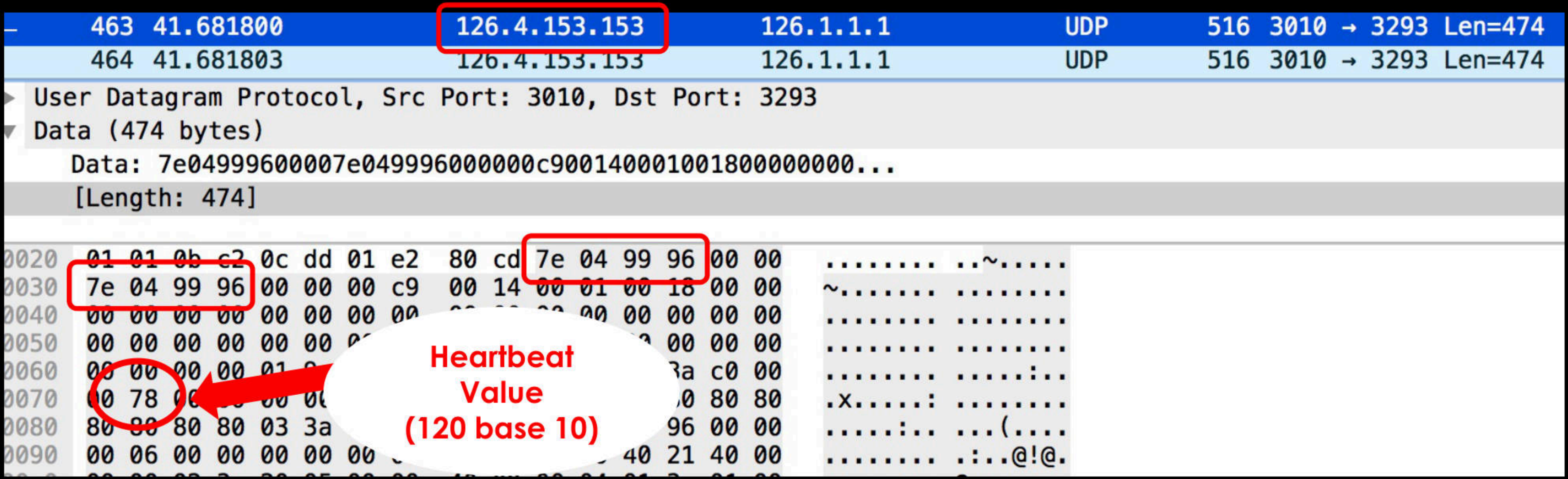

433 39.502117 126.4.153.150 126.1.1.1 UDP 516 3008 → 3293 Len=474
434 39.502119 126.4.153.150 126.1.1.1 UDP 516 3008 → 3293 Len=474
Frame 433: 516 bytes on wire (4128 bits), 516 bytes captured (4128 bits)
Ethernet II, Src: Marquett_04:99:96 (00:00:a1:04:99:96), Dst: Advantec_97:1f:67 (00:d0:c9:97:1f:67)
Internet Protocol Version 4, Src: 126.4.153.150, Dst: 126.1.1.1
User Datagram Protocol, Src Port: 3008, Dst Port: 3293
Data (474 bytes)
Heartbeat
Value
(80 base 10)

INJECTION



Kali Box MAC
433 39.502117 126.4.153.150 126.1.1.1 UDP 516
518 44.230408 126.4.153.153 126.1.1.1 UDP 681 3008 → 3294 Len=639
519 44.250825 126.4.153.150 126.1.1.1 UDP 681 3006 → 3294 Len=639
520 44.250827 126.4.153.150 126.1.1.1 UDP 681 3006 → 3294 Len=639
521 44.402360 Vmware_a1:6e:bf Marquett_04:99:96 ARP 60 126.1.1.1 is at 00:0c:29:a1:6e:bf
522 44.402363 Vmware_a1:6e:bf Marquett_04:99:96 ARP 60 126.1.1.1 is at 00:0c:29:a1:6e:bf
523 44.484103 126.4.153.153 126.1.1.1 UDP 681 3008 → 3294 Len=639
Frame 522: 60 bytes on wire (480 bits), 60 bytes captured (480 bits)
Ethernet II, Src: Vmware_a1:6e:bf (00:0c:29:a1:6e:bf), Dst: Marquett_04:99:96 (00:00:a1:04:99:96)
[Duplicate IP address detected for 126.1.1.1 (00:0c:29:a1:6e:bf) - also in use by 00:d0:c9:97:1f:67 (frame 428)]
[Frame showing earlier use of IP address: 428]
[Seconds since earlier frame seen: 5]
Address Resolution Protocol (reply)
00a0 00 00 02 3a 20 05 00 00 40 09 00 04 01 3a 01 00 ...: ... @....:..

INJECTION



463 41.681800 126.4.153.153 126.1.1.1 UDP 516 3010 → 3293 Len=474
464 41.681803 126.4.153.153 126.1.1.1 UDP 516 3010 → 3293 Len=474
User Datagram Protocol, Src Port: 3010, Dst Port: 3293
Data (474 bytes)
Data: 7e04999600007e049996000000c9001400010018000000000...
[Length: 474]
Heartbeat Value (120 base 10)

DEMO PACKET INJECTION

DEMO PACKET INJECTION 2

IMPACT SCENARIO

- Power of misinformation
- Unconscious patient
- Reliance on technology
- Smaller changes, larger impact

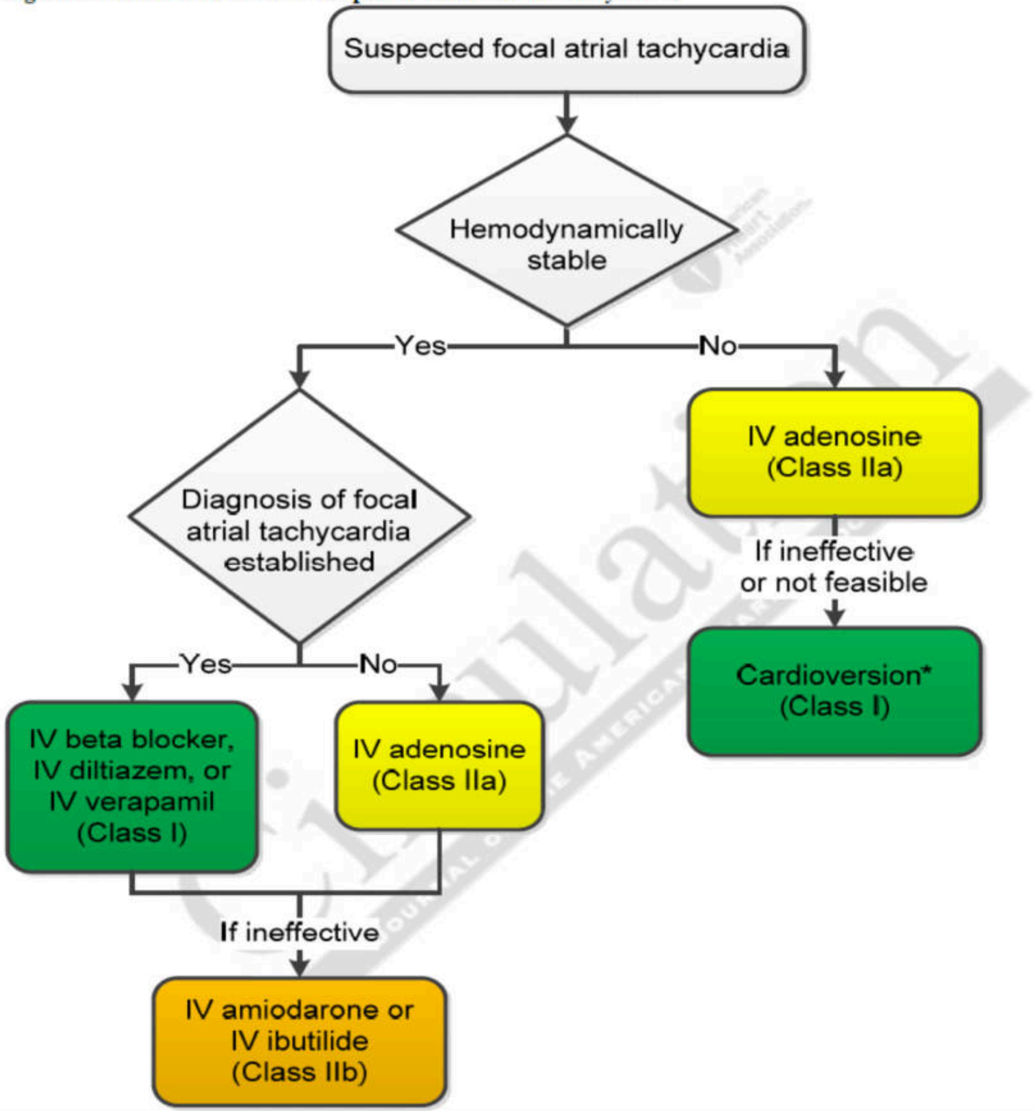
"Fictitious cardiac rhythms, even intermittent, could lead to extended hospitalization, additional testing, and side effects from medications to control heart rhythm and/or prevent clots. The hospital could also suffer resource consumption."

- Dr. S. Nordeck

AMER. HEART ASSOC. & AMER. COLLEGE OF CARDIOLOGY – ARRHYTHMIA MANAGEMENT GUIDELINES

Page RL, et al.
2015 ACC/AHA/HRS SVT Guideline

Figure 10. Acute Treatment of Suspected Focal Atrial Tachycardia

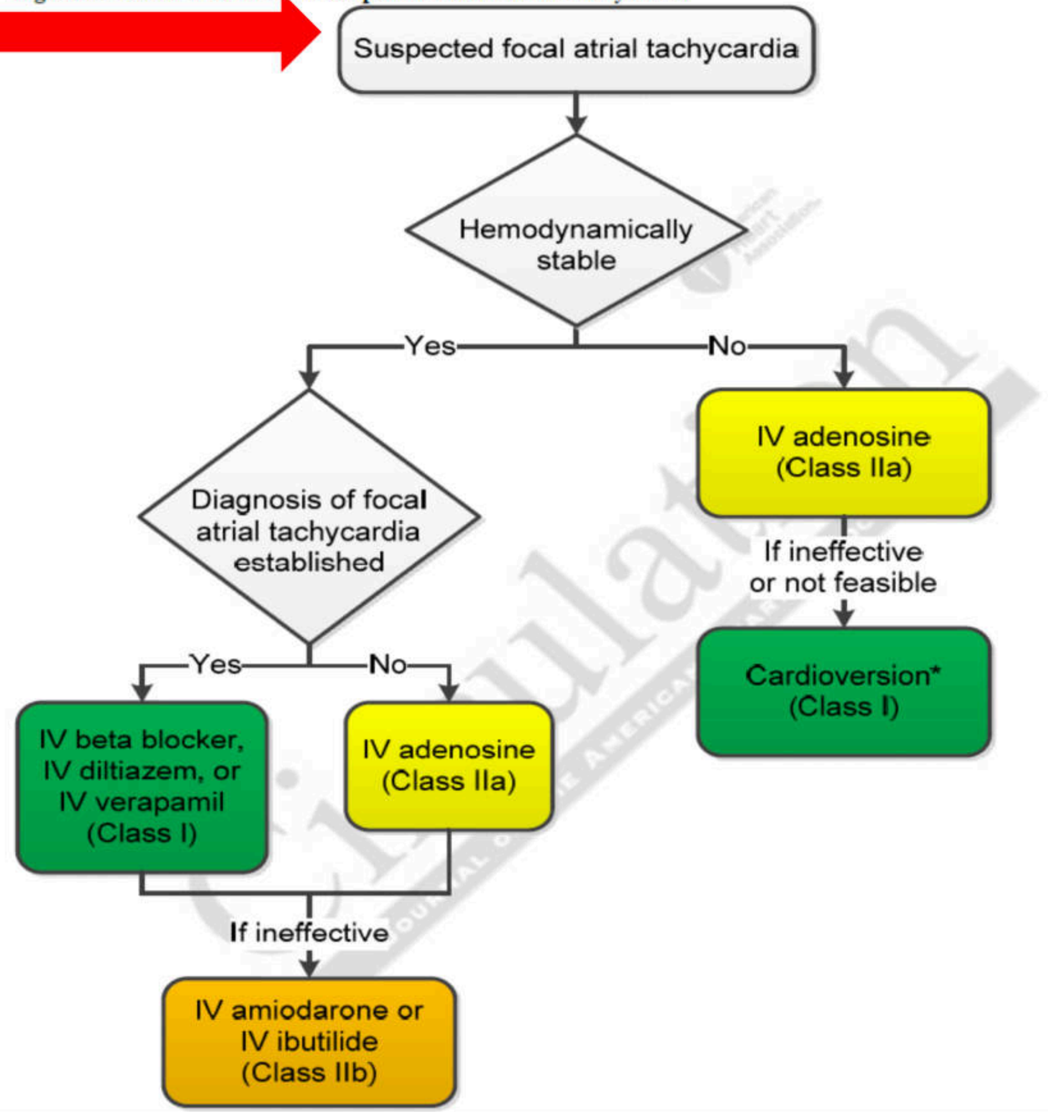


AMER. HEART ASSOC. & AMER. COLLEGE OF CARDIOLOGY – ARRHYTHMIA MANAGEMENT GUIDELINES

Fictitious intermittent cardiac rhythms

Page RL, et al.
2015 ACC/AHA/HRS SVT Guideline

Figure 10. Acute Treatment of Suspected Focal Atrial Tachycardia



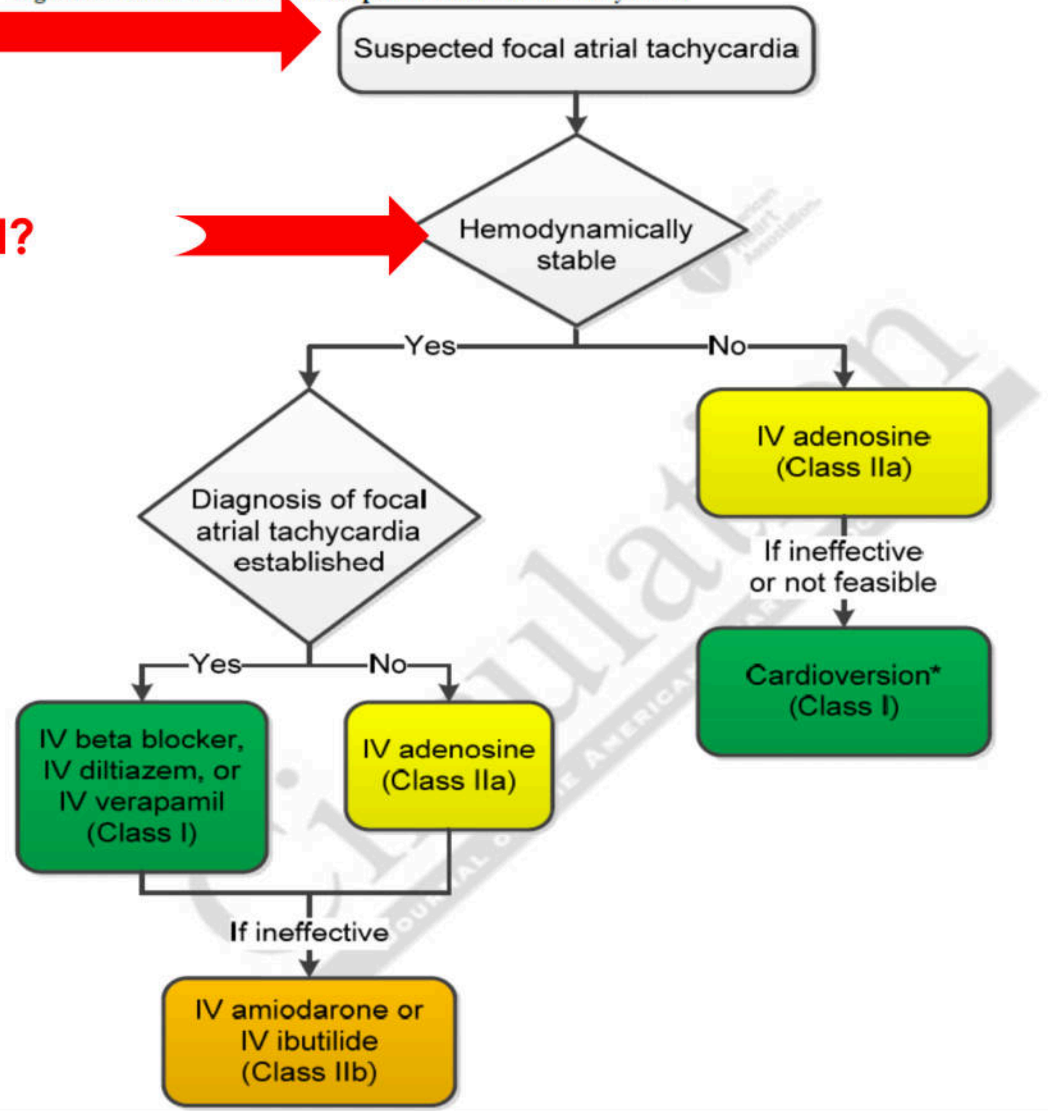
AMER. HEART ASSOC. & AMER. COLLEGE OF CARDIOLOGY – ARRHYTHMIA MANAGEMENT GUIDELINES

Fictitious intermittent cardiac rhythms

Blood Pressure Normal?

Page RL, et al.
2015 ACC/AHA/HRS SVT Guideline

Figure 10. Acute Treatment of Suspected Focal Atrial Tachycardia

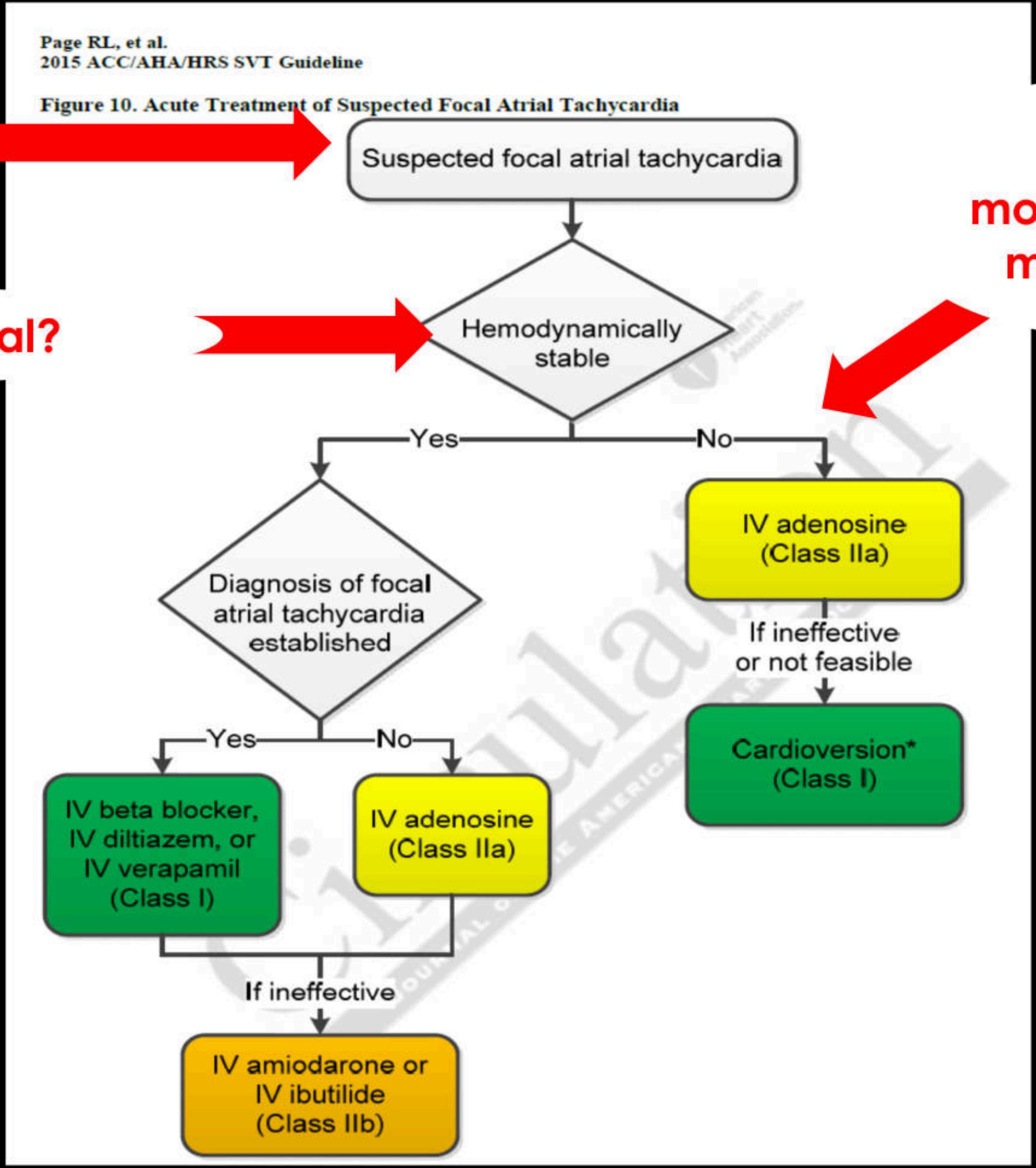


AMER. HEART ASSOC. & AMER. COLLEGE OF CARDIOLOGY – ARRHYTHMIA MANAGEMENT GUIDELINES

Fictitious intermittent cardiac rhythms

Blood Pressure Normal?

If PM monitor was modified

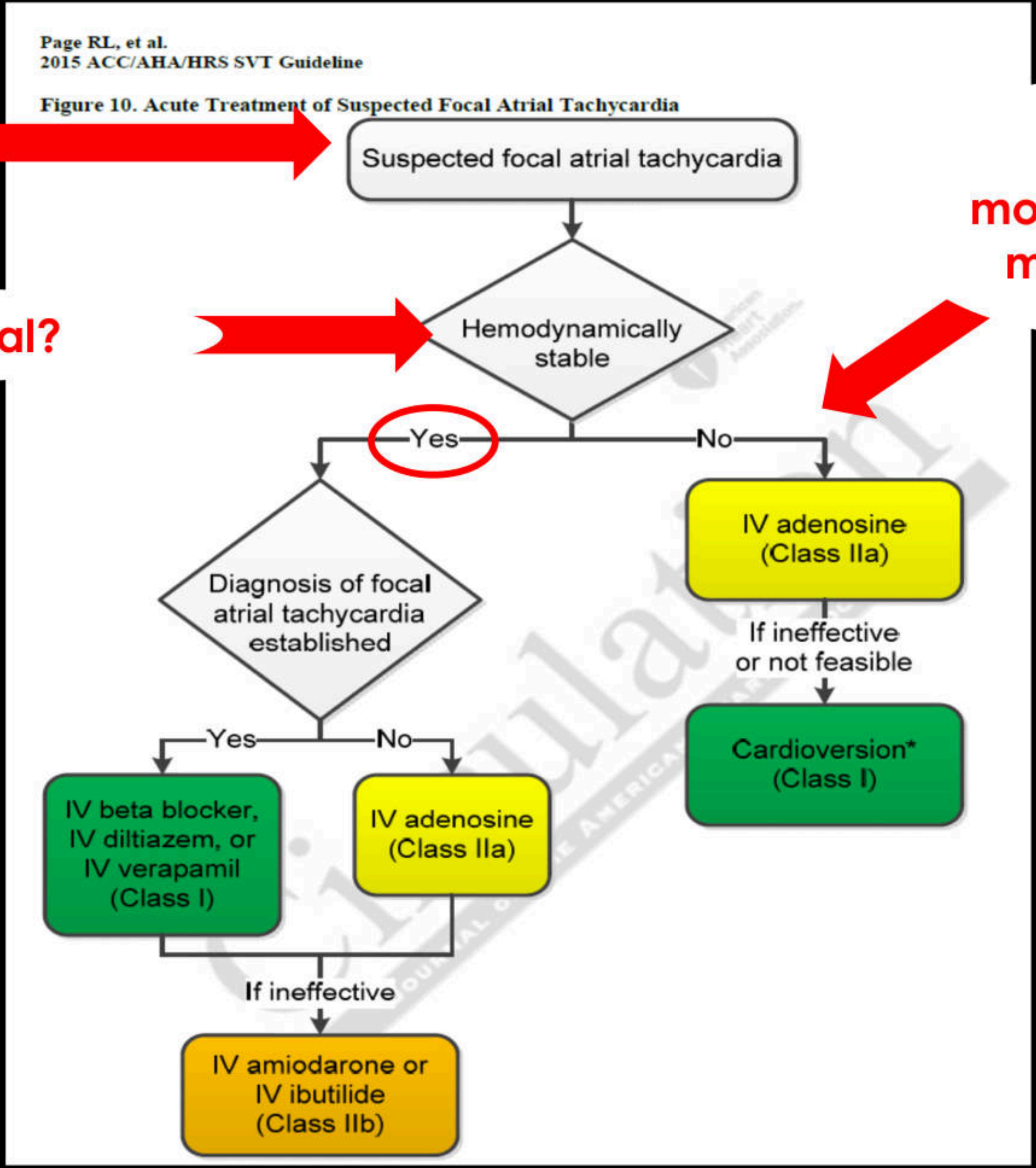


AMER. HEART ASSOC. & AMER. COLLEGE OF CARDIOLOGY – ARRHYTHMIA MANAGEMENT GUIDELINES

Fictitious intermittent cardiac rhythms

Blood Pressure Normal?

If PM monitor was modified



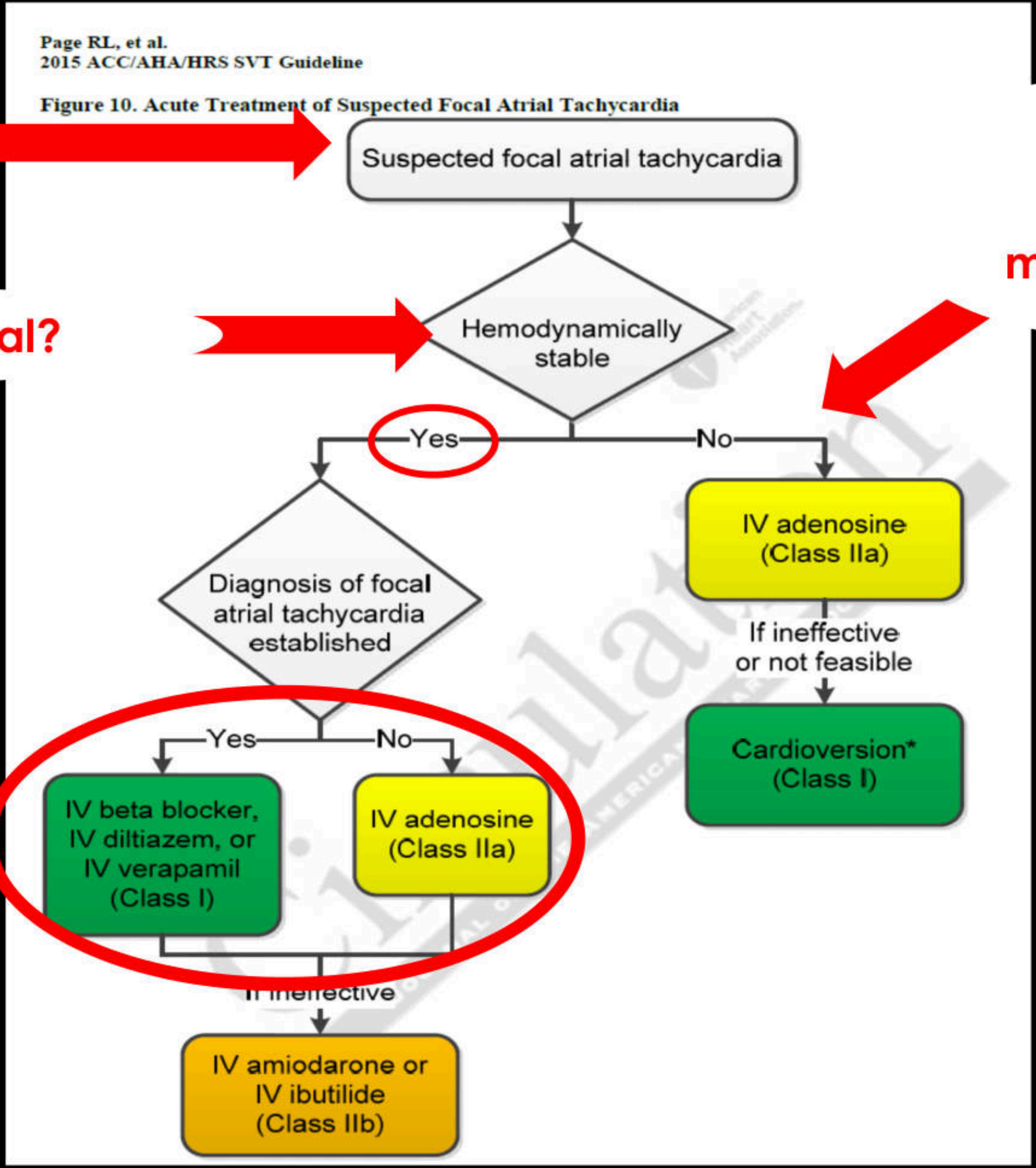
AMER. HEART ASSOC. & AMER. COLLEGE OF CARDIOLOGY – ARRHYTHMIA MANAGEMENT GUIDELINES

Fictitious intermittent cardiac rhythms

Blood Pressure Normal?

Medications Administered

If PM was modified



Mitigations

- Encryption
- Authentication/Authorization
- Isolation
  - Network access controls
  - Physical access control

Other Considerations

- Attacker would require full knowledge of all aspects of the protocol and must create a full consistent set of parameters to avoid detection
- Local monitor continues to show the true state of the patient and cannot be altered by this attacker
    - Monitors do not require a network to function properly

SPECIAL THANKS

- Shaun Nordeck, MD
- Charles McFarland
- McAfee Production team
- ATR

QUESTIONS?